

BÁO CÁO

Giám sát và cảnh báo cho các địa chỉ IP public

Văn phòng Tập đoàn Điện lực Việt Nam

Hà Nội, 11/2025

CyRadar Threat Intelligence Platform

BÁO CÁO TUẦN 44

Giám sát và cảnh báo cho các địa chỉ IP public

Văn phòng Tập đoàn Điện lực Việt Nam

Đơn vị được giám sát	Văn phòng Tập đoàn Điện lực Việt Nam
Địa chỉ	Số 11 phố Cửa Bắc, Phường Trúc Bạch, Quận Ba Đình, thành phố Hà Nội, Việt Nam.
Thời gian giám sát	2025/10/28 12:10:00 – 2025/11/04 12:10:00
Đơn vị triển khai	Công ty Cổ phần An toàn Thông tin CyRadar
Phân loại tài liệu	Giới hạn

MỤC LỤC

TỔNG QUAN.....	4
KHUYẾN NGHỊ KHÁC PHỤC	7
PHỤ LỤC	8
PHỤ LỤC 1. CÔNG DỊCH VỤ ĐANG MỞ	8
PHỤ LỤC 2. GIÁM SÁT CẢNH BÁO CHO TOÀN BỘ ĐỊA CHỈ IP PUBLIC	9
PHỤ LỤC 3. LỘ LỘT TÀI KHOẢN	86
PHỤ LỤC 4. LỘ LỘT TÀI LIỆU	93
PHỤ LỤC 5. LẠM DỤNG THƯƠNG HIỆU	94
PHỤ LỤC 6. YÊU CẦU ĐIỀU TRA	95
PHỤ LỤC 7. IP LIÊN QUAN MÃ ĐỘC/BOTNET	96
PHỤ LỤC 8. CHIẾN DỊCH TẤN CÔNG.....	97
PHỤ LỤC 9. TÀI SẢN GIÁM SÁT	98

TỔNG QUAN

Hệ thống CyRadar Threat Intelligence thực hiện giám sát tài sản của Văn phòng Tập đoàn Điện lực Việt Nam nhằm đưa ra các cảnh báo về nguy cơ an ninh mạng trong hệ thống khách hàng.

Phạm vi giám sát:

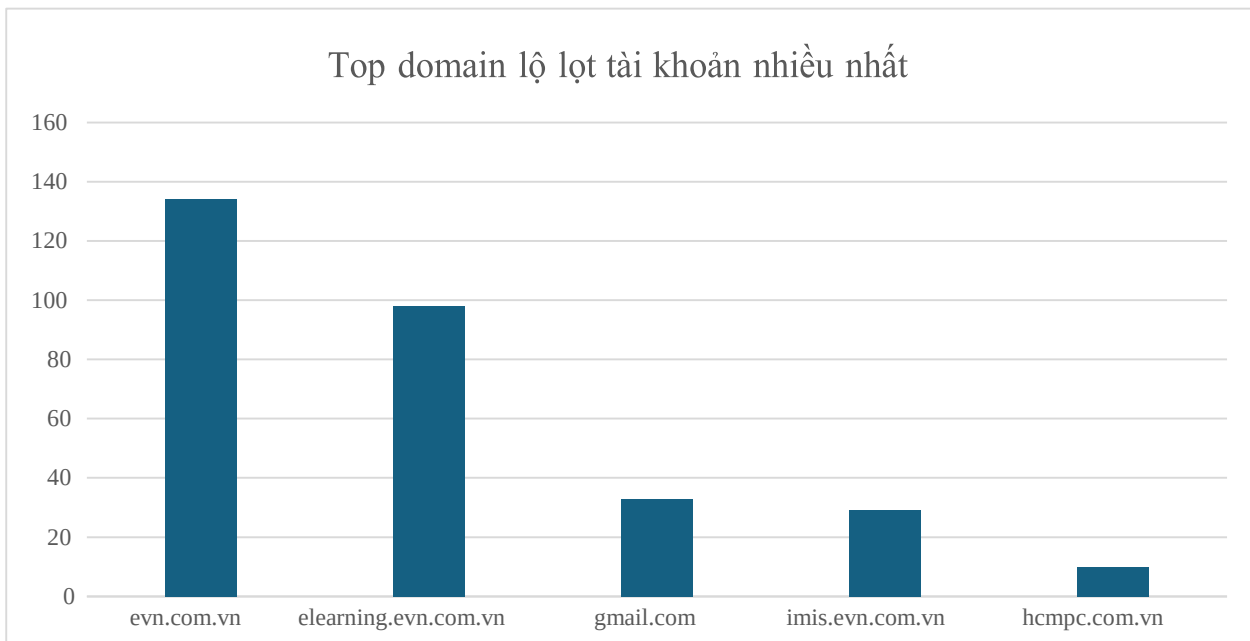
- TTDL miền Bắc: 103.178.214.0/24
- TTDL miền Nam: 103.178.215.0/24
- FTTH tại 11 Cửa Bắc : 117.6.160.162, 222.252.15.96, 117.6.160.195, 113.176.1.94, 117.6.160.160, 113.160.73.118, 117.6.160.164
- FTTH tại VHMN: 115.73.223.66, 14.161.30.37
- FTTH tại VHMT: 117.2.115.205

Báo cáo này bao gồm kết quả giám sát đánh giá về các nguy cơ, mô tả chi tiết các vấn đề đã phát hiện cùng các khuyến nghị để xử lý khắc phục vấn đề.

Thông tin tổng quan

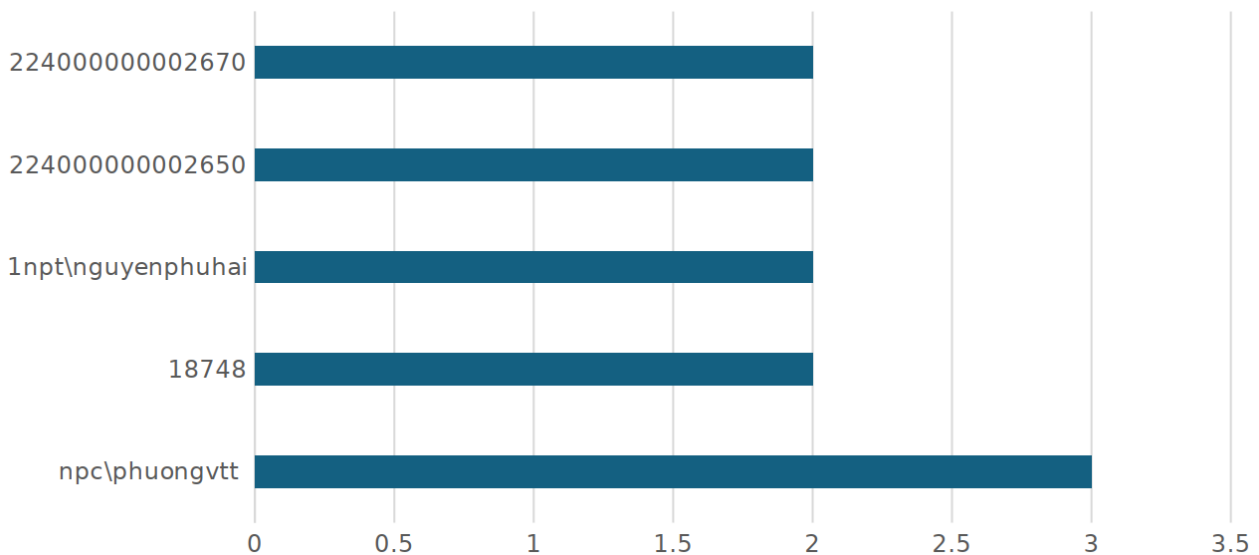
Nguy cơ 595 -27.97 %	Lộ lọt tài khoản 134 +12.61%	Lộ lọt thẻ tín dụng 0 N/A
Lộ lọt tài liệu 0 N/A	Lạm dụng thương hiệu 0 N/A	Botnet 0 N/A
Yêu cầu điều tra 0 / 0 N/A	Chiến dịch tấn công 0 / 8 N/A	Cổng dịch vụ đang mở 17 -46.88 %

Lộ lọt tài khoản

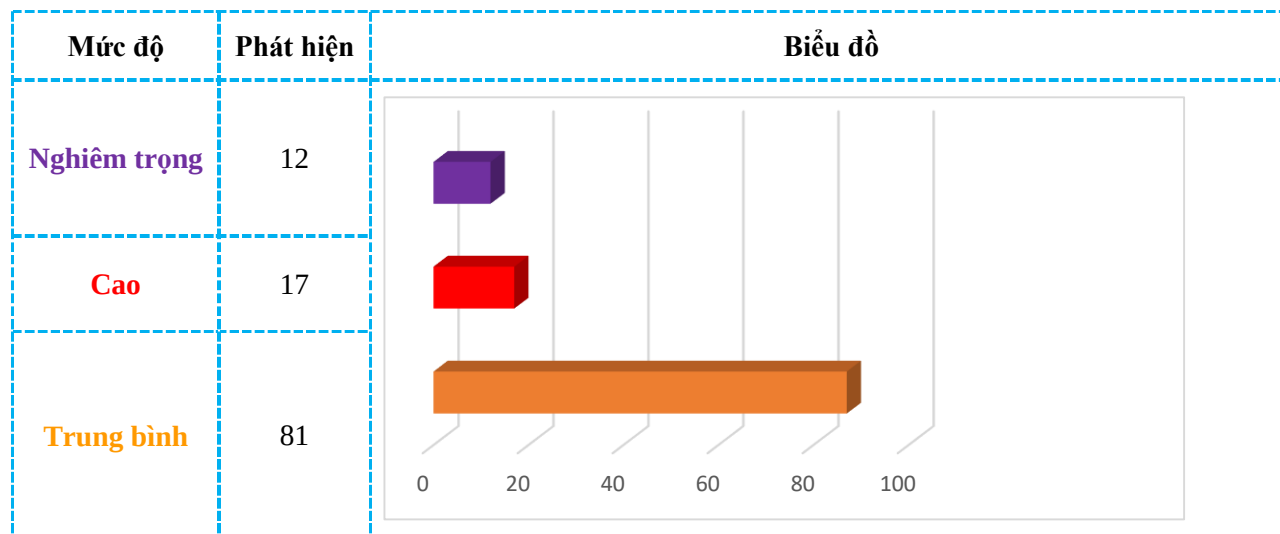


Thông tin tài khoản bị rò rỉ thường xuyên nhất

Top tài khoản lộ lọt nhiều nhất



Lỗ hổng bảo mật



KHUYẾN NGHỊ KHẮC PHỤC

Lỗ hổng bảo mật

- Cập nhật bản vá mới nhất từ nhà cung cấp
- Đối với lỗ hổng nguy hiểm, nếu chưa thể vá, tạm thời vô hiệu hóa tính năng chứa lỗ hổng
- Tăng cường bảo vệ và giám sát bằng Firewall, IDS/IPS, SIEM...
- Ghi log đầy đủ và lưu trữ để phục vụ điều tra sau này
- Kiểm tra lại hệ thống sau xử lý để đảm bảo an toàn

Lộ lọt dữ liệu (thông tin tài khoản, tài liệu, thẻ tín dụng)

- Xác minh dữ liệu bị lộ lọt
- Xử lý khắc phục tùy loại dữ liệu: đổi mật khẩu, vô hiệu hóa API key, khóa thẻ tín dụng, xử lý sự cố truyền thông, thông báo tới khách hàng...
- Khoanh vùng, điều tra nguyên nhân lộ lọt
- Rà soát, làm sạch nguy cơ gây lộ lọt trong hệ thống
- Tăng cường áp dụng các chính sách về ATTT trong nội bộ (phân quyền truy cập, yêu cầu bật xác thực đa lớp, định kỳ đổi mật khẩu, sử dụng phần mềm chống mã độc...)

Bị lạm dụng thương hiệu

- Thông báo tới khách hàng của tổ chức không truy cập vào các tên miền/đường dẫn lừa đảo
- Phối hợp với các cơ quan chức năng để ngăn chặn các tên miền lừa đảo

Liên quan Malware/Botnet

- Xác định và cách ly hệ thống bị nghi nhiễm khỏi mạng nội bộ
- Thu thập logs & dấu vết (IOC) phục vụ điều tra
- Quét toàn bộ hệ thống bằng công cụ Antivirus/EDR và thực hiện rà soát thủ công bằng chuyên gia để đảm bảo phát hiện, gỡ bỏ hoàn toàn mã độc
- Thay đổi mật khẩu của các tài khoản liên quan
- Điều tra đường tấn công, và khắc phục vấn đề
- Giám sát hoạt động mạng chặt chẽ sau khi xử lý

PHỤ LỤC

PHỤ LỤC 1. CÔNG DỊCH VỤ ĐANG MỞ

#	IP	Cổng dịch vụ	Dịch vụ	Phiên bản
1	103.178.214.105	443	ssl/https	
2	103.178.214.103	5222	tcpwrapped	
3	103.178.214.103	10000	ssl/snet-sensor-mgmt?	
4	103.178.214.103	5061	ssl/sip-tls?	
5	103.178.214.103	1720	h323q931?	
6	103.178.214.103	5060	sip?	
7	27.72.30.247	80	ssl/http	Apache
8	27.72.30.247	443	ssl/http	Apache (ASP.NET)
9	103.178.215.100	53		
10	103.178.214.175	443		
11	103.178.214.161	995		
12	103.178.214.161	993		
13	103.178.214.161	143		
14	103.178.214.161	110		
15	103.178.214.161	587		
16	103.178.214.133	25		
17	103.178.214.140	80		

PHỤ LỤC 2. GIÁM SÁT CẢNH BÁO CHO TOÀN BỘ ĐỊA CHỈ IP PUBLIC

CÁC IP/DOMAIN

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
1	103.178.214.138	tcp/443	ManageEngine ServiceDesk Plus < 14.2 (Build 14205) Authentication Bypass Vulnerability	Cao	ManageEngine ServiceDesk Plus tồn tại một lỗ hổng vượt qua xác thực (authentication bypass) khi đăng nhập bằng xác thực hai yếu tố.	Cập nhật lên phiên bản 14.2 (Build 14205) trở lên.
		tcp/443	ManageEngine ServiceDesk Plus < 14.3 (Build 14303) Multiple Vulnerabilities	Cao	ManageEngine ServiceDesk Plus tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau: - CVE-2023-35785: Vượt qua xác thực khi đăng nhập bằng xác thực hai yếu tố - SD-109905: CSRF trong việc giải quyết yêu cầu - SD-110567: CSRF trong log truy cập - SD-110938: Tiết lộ dữ liệu nhạy cảm trong log truy cập - SD-108306: Phiên bản jar của BouncyCastle được nâng cấp lên 1.70 - SD-110596: Leo thang đặc quyền khi mở lại các yêu cầu đã đóng - SD-110596: Leo thang đặc quyền trong bộ hẹn giờ của yêu cầu	Cập nhật lên phiên bản 14.3 (Build 14303) trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	ManageEngine ServiceDesk Plus < 14.8 (Build 14820) XSS Vulnerability	Trung bình	ManageEngine ServiceDesk Plus is prone to a cross-site scripting (XSS) vulnerability. A stored cross-site scripting (XSS) vulnerability allows users to inject malicious JavaScript while creating a new request. This script would be executed whenever a user opens the request details page.	Update to version 14.8 (Build 14820) or later.
		tcp/443	ManageEngine ServiceDesk Plus < 14.9 (Build 14920) XSS Vulnerability	Trung bình	ManageEngine ServiceDesk Plus is prone to a cross-site scripting (XSS) vulnerability. A stored cross-site scripting (XSS) vulnerability allowed authenticated technicians to upload a malicious HTML file during task creation. The payload would be executed when other technicians or administrators (or SDAadmins) interact with the file.	Update to version 14.9 (Build 14920) or later.
		tcp/443	ManageEngine ServiceDesk Plus < 14.2 (Build 14202) Multiple Vulnerabilities	Trung bình	ManageEngine ServiceDesk Plus tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau: - CVE-2023-34197: Leo thang đặc quyền trong mô-đun Release	Cập nhật lên phiên bản 14.2 (Build 14202) trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- SD-107316: Tên người dùng được in trong log - SD-109423: Log không cần thiết được in liên quan đến license - SD-110435: XSS trong trang Community > Schedule Activities nếu tên lịch trình tùy chỉnh chứa nội dung XSS - SD-107754: Leo thang đặc quyền cho phép người dùng tách yêu cầu dịch vụ khỏi đơn hàng - SD-107752: Leo thang đặc quyền cho phép người dùng liên kết yêu cầu dịch vụ vào đơn hàng - SD-107614: Thông tin nhạy cảm bị lộ qua siêu dữ liệu (EXIF) của hình ảnh	
		tcp/443	Missing 'HttpOnly' Cookie Attribute (HTTP)	Trung bình	Máy chủ HTTP / ứng dụng web từ xa đang thiếu việc đặt thuộc tính cookie 'HttpOnly' cho một hoặc nhiều HTTP cookie được gửi đi. Lỗ hổng tồn tại nếu một cookie phiên không sử dụng thuộc tính cookie 'HttpOnly'. Điều này cho phép cookie có thể được truy cập bởi JavaScript, có thể dẫn đến	- Đặt thuộc tính cookie 'HttpOnly' cho bất kỳ cookie phiên nào - Đánh giá / tự đánh giá tác động bảo mật lên máy chủ / ứng dụng web và tạo một ngoại lệ (override) cho kết quả này nếu không có (VT không thể kiểm tra tự động được).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					các cuộc tấn công chiếm đoạt phiên (session hijacking).	
		tcp/443	ManageEngine ServiceDesk Plus Information Disclosure Vulnerability	Trung bình	Một vấn đề đã được phát hiện trong Zoho ManageEngine ServiceDesk Plus. Người dùng chưa xác thực có thể xác thực tài khoản người dùng miền bằng cách gửi một yêu cầu chứa tên người dùng đến một API endpoint. Endpoint sẽ trả về miền đăng nhập của người dùng nếu tài khoản tồn tại hoặc trả về 'null' nếu không tồn tại.	Không có giải pháp nào được công bố trong ít nhất một năm kể từ khi lỗ hổng này được tiết lộ. Có khả năng sẽ không có giải pháp nào được cung cấp nữa. Các tùy chọn giải pháp chung là nâng cấp lên bản phát hành mới hơn, vô hiệu hóa các tính năng tương ứng, gỡ bỏ sản phẩm hoặc thay thế sản phẩm bằng một sản phẩm khác.
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kịch bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-20220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở	

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/443	ManageEngine ServiceDesk Plus < 14.3 (Build 14304) Information Disclosure Vulnerability	Trung bình	ManageEngine ServiceDesk Plus is prone to an information disclosure vulnerability. An information disclosure vulnerability exists in multiple ManageEngine products that can result in encryption keys being exposed. A low-privileged OS user with access to the host where an affected ManageEngine product is installed can view and use the exposed key to decrypt product database passwords. This allows the user to access the ManageEngine product database.	Update to version 14.3 (Build 14304) or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu 4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					(và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn	tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/443	Missing 'Secure' Cookie Attribute (HTTP)	Trung bình	Máy chủ HTTP / ứng dụng web từ xa thiếu việc đặt thuộc tính cookie 'Secure' cho một hoặc nhiều cookie HTTP được gửi đi. Lỗ hổng tồn tại nếu một cookie không sử dụng thuộc tính cookie 'Secure' và được gửi qua kết nối SSL/TLS. Điều này cho phép cookie được chuyển đến máy chủ bởi máy khách qua các kênh không an toàn (HTTP) và sau đó cho phép kẻ tấn công có thể thực hiện các cuộc tấn công chiếm đoạt phiên (session hijacking).	- Đặt thuộc tính cookie 'Secure' cho mọi cookie được gửi qua kết nối SSL/TLS - Đánh giá / tự đánh giá tác động bảo mật lên máy chủ / ứng dụng web và tạo một bản ghi đề (override) cho kết quả này nếu không có (VT không thể kiểm tra tự động được)
		tcp/443	jQuery End of Life (EOL) Detection - Windows	Trung bình	Phiên bản jQuery trên thiết bị từ xa đã đến cuối chu kỳ hỗ trợ (EOL) và không nên được sử dụng nữa.	Cập nhật jQuery trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.
		tcp/443	jQuery < 3.0.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS). Khi một yêu cầu Ajax xuyên miền (cross-domain) được thực hiện mà không có tùy chọn dataType, sẽ khiến cho các phản hồi text/javascript được thực thi.	Cập nhật lên phiên bản 3.0.0 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	jQuery < 3.4.0 Object Extensions Vulnerability	Trung bình	jQuery tồn tại nhiều lỗ hổng liên quan đến việc chèn thuộc tính vào Object.prototype. Tồn tại các lỗ hổng sau đây: - CVE-2019-5428: Một lỗ hổng prototype pollution cho phép kẻ tấn công chèn các thuộc tính vào Object.prototype. - CVE-2019-11358: jQuery xử lý không đúng cách jQuery.extend(true, {}, ...) do Object.prototype bị chèn thêm (Object.prototype pollution). Nếu một đối tượng nguồn chưa được kiểm duyệt có chứa một thuộc tính __proto__ có thể liệt kê (enumerable), nó có thể mở rộng (extend) Object.prototype gốc.	Cập nhật lên phiên bản 3.4.0 hoặc mới hơn. Các bản vá lỗi (patch diff) có sẵn cho các phiên bản cũ hơn.
		tcp/443	jQuery 1.2 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) trong jQuery.htmlPrefilter và các phương thức liên quan. Việc truyền HTML từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery	Cập nhật lên phiên bản 3.5.0 trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					(ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	
		tcp/443	jQuery 1.0.3 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) khi thêm (append) HTML chứa các phân tử option. Việc truyền HTML chứa các phân tử <option> từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	Cập nhật lên phiên bản 3.5.0 trở lên.
		tcp/443	PHP < 8.1.31, 8.2.x < 8.2.26, 8.3.x < 8.3.14 Multiple Vulnerabilities - Linux	Nghiêm trọng	PHP is prone to multiple vulnerabilities. The following vulnerabilities exist: - CVE-2024-8929: Leak partial content of the heap through heap buffer overread - CVE-2024-8932: OOB access in ldap_escape - CVE-2024-11233: Single byte overread with	Update to version 8.1.31, 8.2.26, 8.3.14 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					convert.quotedprintable-decode filter - CVE-2024-11234:Configuring a proxy in a stream context might allow for CRLF injection in URIs - CVE-2024-11236:Integer overflow in the firebird/dblib quoter causing OOB writes - No CVE: Heap-Use-After-Free in sapi_read_post_data Processing in CLI SAPI Interface	
		tcp/443	PHP < 8.1.32, 8.2.x < 8.2.28 Multiple Vulnerabilities - Linux	Nghiêm trọng	PHP is prone to multiple vulnerabilities. The following vulnerabilities exist: - CVE-2025-1217: Header parser of 'http' stream wrapper does not handle folded headers - CVE-2025-1219: libxml streams use wrong 'content-type' header when requesting a redirected resource - CVE-2025-1734: Streams HTTP wrapper does not fail for headers without colon	Update to version 8.1.32, 8.2.28 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2025-1736: Stream HTTP wrapper header check might omit basic auth header - CVE-2025-1861: Stream HTTP wrapper truncate redirect location to 1024 bytes	
		tcp/443	PHP < 8.1.33, 8.2.x < 8.2.29, 8.3.x < 8.3.23, 8.4.x < 8.4.10 Multiple Vulnerabilities - Linux	Cao	PHP is prone to multiple vulnerabilities. The following vulnerabilities exist: - CVE-2025-1220: Null byte termination in hostnames - CVE-2025-1735: pgsql extension does not check for errors during escaping - CVE-2025-6491: NULL pointer dereference in PHP SOAP extension via large XML namespace prefix	Update to version 8.1.33, 8.2.29, 8.3.23, 8.4.10 or later.
2	27.72.30.247	tcp/443	Sensitive File Disclosure (HTTP)	Cao	Script này cố gắng xác định các tệp chứa dữ liệu nhạy cảm trên máy chủ web từ xa. Hiện tại, script này đang kiểm tra các tệp như sau: - Các tệp cấu hình hoặc nhật ký của phần mềm (Blog, CMS) - Các tệp cấu hình/mật khẩu của máy chủ web/ứng dụng	Các tệp nhạy cảm không nên có thể truy cập được thông qua máy chủ web. Hạn chế quyền truy cập vào tệp đó hoặc xóa hoàn toàn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					(.htaccess, .htpasswd, web.config, web.xml, ...) - Các tệp cấu hình đám mây (ví dụ: AWS) - Các tệp chứa API key của các dịch vụ/nhà cung cấp - Các tệp sao lưu cơ sở dữ liệu - Các tệp trình soạn thảo/ lịch sử - SSH hoặc SSL/TLS Private Keys	
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu 4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
3	103.178.214.103	tcp/10000	jQuery End of Life (EOL) Detection - Linux	Trung bình	Phiên bản jQuery trên thiết bị từ xa đã đến cuối chu kỳ	Cập nhật jQuery trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					hỗ trợ (EOL) và không nên được sử dụng nữa.	
		tcp/443	jQuery End of Life (EOL) Detection - Linux	Trung bình	Phiên bản jQuery trên thiết bị từ xa đã đến cuối chu kỳ hỗ trợ (EOL) và không nên được sử dụng nữa.	Cập nhật jQuery trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.
		tcp/5601	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ	

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					hồng này cùng với CVE-2002-20001.	
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/10000	Diffie-Hellman Ephemeral Key	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
			Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)		DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kịch bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và	nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/5061	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như:	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	
		tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.
		tcp/10000	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như:	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu 4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/10000	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream	4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/443	jQuery < 3.0.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS). Khi một yêu cầu Ajax xuyên miền (cross-domain) được thực hiện mà không có tùy chọn dataType, sẽ khiến cho các phản hồi text/javascript được thực thi.	Cập nhật lên phiên bản 3.0.0 hoặc mới hơn.
		tcp/443	jQuery < 3.4.0 Object Extensions Vulnerability	Trung bình	jQuery tồn tại nhiều lỗ hổng liên quan đến việc chèn thuộc tính vào Object.prototype. Tồn tại các lỗ hổng sau đây: - CVE-2019-5428: Một lỗ hổng prototype pollution cho phép kẻ tấn công chèn các thuộc tính vào Object.prototype. - CVE-2019-11358: jQuery xử lý không đúng cách jQuery.extend(true, {}, ...) do Object.prototype bị chèn	Cập nhật lên phiên bản 3.4.0 hoặc mới hơn. Các bản vá lỗi (patch diff) có sẵn cho các phiên bản cũ hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					thêm (Object.prototype pollution). Nếu một đối tượng nguồn chưa được kiểm duyệt có chứa một thuộc tính __proto__ có thể liệt kê (enumerable), nó có thể mở rộng (extend) Object.prototype gốc.	
		tcp/443	jQuery 1.2 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) trong jQuery.htmlPrefilter và các phương thức liên quan. Việc truyền HTML từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	Cập nhật lên phiên bản 3.5.0 trở lên.
		tcp/443	jQuery 1.0.3 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) khi thêm (append) HTML chứa các phân tử option. Việc truyền HTML chứa các phân tử <option> từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong	Cập nhật lên phiên bản 3.5.0 trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	
		tcp/10000	jQuery < 3.0.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS). Khi một yêu cầu Ajax xuyên miền (cross-domain) được thực hiện mà không có tùy chọn dataType, sẽ khiến cho các phản hồi text/javascript được thực thi.	Cập nhật lên phiên bản 3.0.0 hoặc mới hơn.
		tcp/10000	jQuery < 3.4.0 Object Extensions Vulnerability	Trung bình	jQuery tồn tại nhiều lỗ hổng liên quan đến việc chèn thuộc tính vào Object.prototype. Tồn tại các lỗ hổng sau đây: - CVE-2019-5428: Một lỗ hổng prototype pollution cho phép kẻ tấn công chèn các thuộc tính vào Object.prototype. - CVE-2019-11358: jQuery xử lý không đúng cách jQuery.extend(true, {}, ...) do Object.prototype bị chèn thêm (Object.prototype pollution). Nếu một đối tượng nguồn chưa được kiểm duyệt có chứa một	Cập nhật lên phiên bản 3.4.0 hoặc mới hơn. Các bản vá lỗi (patch diff) có sẵn cho các phiên bản cũ hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					thuộc tính __proto__ có thể liệt kê (enumerable), nó có thể mở rộng (extend) Object.prototype gốc.	
		tcp/10000	jQuery 1.2 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) trong jQuery.htmlPrefilter và các phương thức liên quan. Việc truyền HTML từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	Cập nhật lên phiên bản 3.5.0 trở lên.
		tcp/10000	jQuery 1.0.3 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) khi thêm (append) HTML chứa các phân tử option. Việc truyền HTML chứa các phân tử <option> từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể	Cập nhật lên phiên bản 3.5.0 trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					thực thi mã không đáng tin cậy.	
		tcp/5061	SSL/TLS: DiffieHellman Key Exchange Insufficient DH Group Strength Vulnerability	Trung bình	Dịch vụ SSL/TLS sử dụng các nhóm Diffie-Hellman có độ mạnh không đủ (kích thước khóa < 2048). Nhóm DiffieHellman là một số các số lớn được sử dụng làm cơ sở cho các tính toán DH. Chúng có thể được xác định trước và thường được xác định trước. Độ bảo mật của bí mật cuối cùng phụ thuộc vào kích thước của các tham số này. Các số 512 và 768 bit được xác định là yếu, 1024 bit có thể bị bẻ vào bởi các kẻ tấn công thực sự mạnh như các cơ quan chính phủ.	Triển khai (Ephemeral) EllipticCurve Diffie-Hellman (ECDHE) hoặc sử dụng nhóm DiffieHellman có độ dài 2048 bit trở lên (xem các liên kết tham chiếu). Đối với Apache Web Servers: Bắt đầu từ phiên bản 2.4.7, mod_ssl sẽ sử dụng các tham số DH bao gồm các số nguyên tố có độ dài lớn hơn 1024 bit.
		tcp/443	SSL/TLS: DiffieHellman Key Exchange Insufficient DH Group Strength Vulnerability	Trung bình	Dịch vụ SSL/TLS sử dụng các nhóm Diffie-Hellman có độ mạnh không đủ (kích thước khóa < 2048). Nhóm DiffieHellman là một số các số lớn được sử dụng làm cơ sở cho các tính toán DH. Chúng có thể được xác định trước và thường được xác định trước. Độ bảo mật của bí mật cuối cùng phụ thuộc vào kích thước của các tham số này. Các số 512 và 768 bit được xác định là yếu,	Triển khai (Ephemeral) EllipticCurve Diffie-Hellman (ECDHE) hoặc sử dụng nhóm DiffieHellman có độ dài 2048 bit trở lên (xem các liên kết tham chiếu). Đối với Apache Web Servers: Bắt đầu từ phiên bản 2.4.7, mod_ssl sẽ sử dụng các tham số DH bao gồm các số nguyên tố có độ dài lớn hơn 1024 bit.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					1024 bit có thể bị bẻ vào bởi các kẻ tấn công thực sự mạnh như các cơ quan chính phủ.	
		tcp/10000	SSL/TLS: DiffieHellman Key Exchange Insufficient DH Group Strength Vulnerability	Trung bình	Dịch vụ SSL/TLS sử dụng các nhóm Diffie-Hellman có độ mạnh không đủ (kích thước khóa < 2048). Nhóm DiffieHellman là một số các số lớn được sử dụng làm cơ sở cho các tính toán DH. Chúng có thể được xác định trước và thường được xác định trước. Độ bảo mật của bí mật cuối cùng phụ thuộc vào kích thước của các tham số này. Các số 512 và 768 bit được xác định là yếu, 1024 bit có thể bị bẻ vào bởi các kẻ tấn công thực sự mạnh như các cơ quan chính phủ.	Triển khai (Ephemeral) EllipticCurve Diffie-Hellman (ECDHE) hoặc sử dụng nhóm DiffieHellman có độ dài trở lên (xem các liên kết tham chiếu). Đối với Apache Web Servers: Bắt đầu từ phiên bản 2.4.7, mod_ssl sẽ sử dụng các tham số DH bao gồm các số nguyên tố có độ dài lớn hơn 1024 bit.
4	103.178.214.212	tcp/443	Microsoft Exchange Server OWA Multiple Vulnerabilities (KB5019758, ProxyNotShell) - Active Check	Nghiêm trọng	Microsoft Exchange Server tồn tại nhiều lỗ hổng trong Outlook Web App (OWA), được gọi chung là 'ProxyNotShell'. Tồn tại các lỗ hổng sau: - CVE-2022-41040: Lỗ hổng Server-SideRequest Forgery (SSRF) - CVE-2022-41082: Thực thi mã từ xa (RCE) khi	- Áp dụng bản cập nhật KB5019758 do nhà cung cấp cung cấp hoặc - Áp dụng các bước giảm thiểu rủi ro được cung cấp bởi nhà cung cấp trong bài đăng blog được liên kết Lưu ý: - Hãy đảm bảo áp dụng các khuyến nghị giảm thiểu mới nhất vì chúng đã được cập nhật nhiều lần. - Hãy tạo một bản ghi đè (override) cho kết quả này nếu bản cập nhật KB5019758 đã được áp dụng vì một số cấu hình / môi

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					PowerShell có thể truy cập được bởi kẻ tấn công Một trong các lỗ hổng tồn tại trong điểm cuối (endpoint) 'autodiscover/autodiscover.json' của OWA và hiện đang được khai thác bởi một chiến dịch tấn công mới để thực thi mã từ xa trên mục tiêu bị ảnh hưởng. Xem các liên kết tham chiếu để biết thêm chi tiết kỹ thuật và chỉ báo bị xâm nhập (IOCs).	trường cụ thể vẫn có thể được báo cáo là có lỗ hổng (biểu thị bằng QoD thấp hơn là 70%/remote_analysis đối với VT này).
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-2022-0001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói	

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		Tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.
5	103.178.214.180	tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn	- Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
6	103.178.214.164	tcp/443	Apache Axis End of Life (EOL) Detection	Nghiêm trọng	The Apache Axis installation on the remote host has reached the End of Life (EOL) / is discontinued and should not be used anymore.	Axis 1 has been EOL and the vendor recommend to migrate to a different SOAP engine, such as Apache Axis2/Java. Notes: - The latest available version 1.4 was released on April 22, 2006. Some more recent flaws have been fixed only in the SVN repository - The Apache Axis project does not expect to create an Axis 1.x release fixing these flaws

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
						- If the remote installation has been build from the SVN sources or is covered via 'backports' of a Linux distribution please create an override for this result
		tcp/443	jQuery End of Life (EOL) Detection - Linux	Trung bình	Phiên bản jQuery trên thiết bị từ xa đã đến cuối chu kỳ hỗ trợ (EOL) và không nên được sử dụng nữa.	Cập nhật jQuery trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.
		tcp/443	Apache Axis <= 1.4 Multiple Vulnerabilities	Trung bình	Apache Axis tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau: - CVE-2012-5784: Vượt qua xác thực SSL certificate - CVE-2014-3596: Xác thực chứng thư không an toàn - CVE-2018-8032: Cross-site scripting (XSS) trong default servlet/services - CVE-2019-0227: Server-side request forgery (SSRF) - CVE-2023-40743: Thực thi mã từ xa (RCE) - CVE-2023-51441: SSRF	Nhà cung cấp không đưa ra giải pháp. Các tùy chọn giải pháp chung là nâng cấp lên bản phát hành mới hơn, vô hiệu hóa các tính năng tương ứng, gỡ bỏ sản phẩm hoặc thay thế sản phẩm bằng sản phẩm khác. Lưu ý: - Axis 1 đã ngừng hỗ trợ (EOL) và nhà cung cấp khuyến nghị chuyển sang một SOAP engine khác, chẳng hạn như Apache Axis2/Java - Phiên bản 1.4 được phát hành vào ngày 22 tháng 4 năm 2006 và một số lỗ hổng chỉ được sửa trong SVN repository, có thể được sử dụng để giảm thiểu các lỗ hổng này - Dự án Apache Axis không dự định phát hành Axis 1.x để khắc phục các lỗ hổng này - Nếu bản cài đặt từ xa được build từ SVN sources hoặc được bảo vệ bằng 'backports' của một bản phân phối Linux, hãy tạo một bản ghi đè (override) cho kết quả này
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
			Vulnerability (SSL/TLS, D(HE)ater)		(DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể	bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản	4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/443	jQuery < 3.0.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS). Khi một yêu cầu Ajax xuyên miền (cross-domain) được thực hiện mà không có tùy chọn dataType, sẽ khiến cho các phản hồi text/javascript được thực thi.	Cập nhật lên phiên bản 3.0.0 hoặc mới hơn.
		tcp/443	jQuery < 3.4.0 Object Extensions Vulnerability	Trung bình	jQuery tồn tại nhiều lỗ hổng liên quan đến việc chèn thuộc tính vào Object.prototype. Tồn tại các lỗ hổng sau đây: - CVE-2019-5428: Một lỗ hổng prototype pollution cho phép kẻ tấn công chèn các thuộc tính vào Object.prototype. - CVE-2019-11358: jQuery xử lý không đúng cách jQuery.extend(true, {}, ...) do Object.prototype bị chèn thêm (Object.prototype	Cập nhật lên phiên bản 3.4.0 hoặc mới hơn. Các bản vá lỗi (patch diff) có sẵn cho các phiên bản cũ hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					pollution). Nếu một đối tượng nguồn chưa được kiểm duyệt có chứa một thuộc tính __proto__ có thể liệt kê (enumerable), nó có thể mở rộng (extend) Object.prototype gốc.	
		tcp/443	jQuery 1.2 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) trong jQuery.htmlPrefilter và các phương thức liên quan. Việc truyền HTML từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	Cập nhật lên phiên bản 3.5.0 trở lên.
		tcp/443	jQuery 1.0.3 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) khi thêm (append) HTML chứa các phân tử option. Việc truyền HTML chứa các phân tử <option> từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery	Cập nhật lên phiên bản 3.5.0 trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					(ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	
7	103.178.214.105	tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE.	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán).	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu 4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/443	SSL/TLS: DiffieHellman Key Exchange Insufficient DH Group Strength Vulnerability	Trung bình	Dịch vụ SSL/TLS sử dụng các nhóm Diffie-Hellman có độ mạnh không đủ (kích thước khóa < 2048). Nhóm DiffieHellman là một số các số lớn được sử dụng làm cơ sở cho các tính toán DH. Chúng có thể được xác định trước và thường được xác định trước. Độ bảo mật của bí mật cuối cùng phụ thuộc vào kích thước của các tham số này. Các số 512 và 768 bit được xác định là yếu, 1024 bit có thể bị bẻ vào bởi	Triển khai (Ephemeral) EllipticCurve Diffie-Hellman (ECDHE) hoặc sử dụng nhóm DiffieHellman có độ dài trở lên (xem các liên kết tham chiếu). Đối với Apache Web Servers: Bắt đầu từ phiên bản 2.4.7, mod_ssl sẽ sử dụng các tham số DH bao gồm các số nguyên tố có độ dài lớn hơn 1024 bit.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					các kẻ tấn công thực sự mạnh như các cơ quan chính phủ.	
		tcp/443	Missing 'HttpOnly' Cookie Attribute (HTTP)	Trung bình	Máy chủ HTTP / ứng dụng web từ xa đang thiếu việc đặt thuộc tính cookie 'HttpOnly' cho một hoặc nhiều HTTP cookie được gửi đi. Lỗ hổng tồn tại nếu một cookie phiên không sử dụng thuộc tính cookie 'HttpOnly'. Điều này cho phép cookie có thể được truy cập bởi JavaScript, có thể dẫn đến các cuộc tấn công chiếm đoạt phiên (session hijacking).	- Đặt thuộc tính cookie 'HttpOnly' cho bất kỳ cookie phiên nào - Đánh giá / tự đánh giá tác động bảo mật lên máy chủ / ứng dụng web và tạo một ngoại lệ (override) cho kết quả này nếu không có (VT không thể kiểm tra tự động được).
		tcp/443	Missing 'Secure' Cookie Attribute (HTTP)	Trung bình	Máy chủ HTTP / ứng dụng web từ xa thiếu việc đặt thuộc tính cookie 'Secure' cho một hoặc nhiều cookie HTTP được gửi đi. Lỗ hổng tồn tại nếu một cookie không sử dụng thuộc tính cookie 'Secure' và được gửi qua kết nối SSL/TLS. Điều này cho phép cookie được chuyển đến máy chủ bởi máy khách qua các kênh không an toàn (HTTP) và sau đó cho phép kẻ tấn công có thể thực hiện các cuộc tấn công chiếm đoạt phiên (session hijacking).	- Đặt thuộc tính cookie 'Secure' cho mọi cookie được gửi qua kết nối SSL/TLS - Đánh giá / tự đánh giá tác động bảo mật lên máy chủ / ứng dụng web và tạo một bản ghi đè (override) cho kết quả này nếu không có (VT không thể kiểm tra tự động được)

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
8	103.178.214.224	tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
9	103.178.214.175	tcp/443	Apache Axis End of Life (EOL) Detection	Nghiêm trọng	The Apache Axis installation on the remote host has reached the End of Life (EOL) / is discontinued	Axis 1 has been EOL and the vendor recommend to migrate to a different SOAP engine, such as Apache Axis2/Java. Notes:

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					and should not be used anymore.	- The latest available version 1.4 was released on April 22, 2006. Some more recent flaws have been fixed only in the SVN repository - The Apache Axis project does not expect to create an Axis 1.x release fixing these flaws - If the remote installation has been build from the SVN sources or is covered via 'backports' of a Linux distribution please create an override for this result
		tcp/443	Apache Tomcat End of Life (EOL) Detection - Linux	Nghiêm trọng	Phiên bản Apache Tomcat trên thiết bị từ xa đã đến cuối chu kỳ hỗ trợ (EOL) và không nên được sử dụng nữa.	Cập nhật phiên bản Apache Tomcat trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.
		tcp/443	Apache Tomcat RCE Vulnerability (Mar 2025) - Linux	Nghiêm trọng	Apache Tomcat is prone to a remote code execution (RCE) vulnerability. The original implementation of partial PUT used a temporary file based on the user provided file name and path with the path separator replaced by '.'. If all of the following are true, a malicious user is able to view security sensitive files and/or inject content into those files:	Update to version 9.0.99, 10.1.35, 11.0.3 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- writes enabled for the default servlet (disabled by default) - support for partial PUT (enabled by default) - a target URL for security sensitive uploads that is a sub-directory of a target URL for public uploads - attacker knowledge of the names of security sensitive files being uploaded - the security sensitive files also being uploaded via partial PUT If all of the following are true, a malicious user is able to perform remote code execution: - writes enabled for the default servlet (disabled by default) - support for partial PUT (enabled by default) - application is using Tomcat's file based session persistence with the default storage location - application includes a library that may be leveraged in a deserialization attack	

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	Apache Tomcat Rewrite Rule Bypass Vulnerability (Apr 2025) - Linux	Nghiêm trọng	Apache Tomcat is prone to a rewrite rule bypass vulnerability. For a subset of unlikely rewrite rule configurations, it is possible for a specially crafted request to bypass some rewrite rules. If those rewrite rules effectively enforced security constraints, those constraints could be bypassed.	Update to version 9.0.104, 10.1.40, 11.0.6 or later.
		tcp/443	Apache Tomcat DoS Vulnerability (Feb 2023) - Linux	Cao	Apache Tomcat tồn tại một lỗ hổng từ chối dịch vụ (DoS). Apache Tomcat sử dụng một bản sao Apache Commons FileUpload được đổi tên và đóng gói để cung cấp chức năng tải tệp được định nghĩa trong đặc tả Jakarta Servlet. Do đó, Apache Tomcat cũng bị ảnh hưởng bởi lỗ hổng Apache Commons FileUpload CVE2023-24998 do không có giới hạn số lượng phần yêu cầu được xử lý. Điều này dẫn đến khả năng kẻ tấn công kích hoạt tấn công DoS bằng cách tải lên một hoặc nhiều tệp tin độc hại.	Cập nhật lên phiên bản 8.5.85, 9.0.71, 10.1.5, 11.0.0-M3 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	Apache Tomcat Session Fixation Vulnerability (Aug 2025) - Linux	Cao	Apache Tomcat is prone to a session fixation vulnerability. If the rewrite valve was enabled for a web application, an attacker was able to craft a URL that, if a victim clicked on it, would cause the victim's interaction with that resource to occur in the context of the attacker's session.	Update to version 9.0.106, 10.1.42, 11.0.8 or later.
		tcp/443	Apache Tomcat Request Smuggling Vulnerability (Oct 2022) - Linux	Cao	Apache Tomcat tồn tại lỗ hổng request smuggling. Nếu Tomcat được cấu hình để bỏ qua các header HTTP không hợp lệ bằng cách đặt <code>rejectIllegalHeader</code> thành <code>false</code> (mặc định đối với 8.5.x), Tomcat sẽ không từ chối yêu cầu có chứa header <code>ContentLength</code> không hợp lệ, làm cho tấn công request smuggling trở thành có thể nếu Tomcat nằm sau một reverse proxy cũng không từ chối yêu cầu có header không hợp lệ.	Cập nhật lên phiên bản 8.5.83, 9.0.68, 10.0.27, 10.1.1 hoặc mới hơn.
		tcp/443	Apache Tomcat Request Smuggling Vulnerability (Nov 2023) - Linux	Cao	Apache Tomcat tồn tại lỗ hổng request smuggling. Tomcat không phân tích cú pháp các HTTP trailer	Cập nhật lên phiên bản 8.5.96, 9.0.83, 10.1.16, 11.0.0-M11 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					header một cách chính xác. Một trailer header được tạo thủ công một cách đặc biệt vượt quá giới hạn kích thước header có thể khiến cho Tomcat xử lý một yêu cầu duy nhất như nhiều yêu cầu, dẫn đến khả năng xảy ra request smuggling khi ở phía sau một reverse proxy.	
		tcp/443	Apache Tomcat DoS Vulnerability (Jul 2024) - Linux	Cao	Apache Tomcat tồn tại lỗ hổng từ chối dịch vụ (DoS). Khi xử lý một HTTP/2 stream, Tomcat đã không xử lý đúng cách một số trường hợp HTTP header quá dài. Điều này dẫn đến việc đếm sai số HTTP/2 stream đang hoạt động, sau đó dẫn đến việc sử dụng timeout vô hạn không chính xác, cho phép các kết nối duy trì ở trạng thái mở trong khi lẽ ra phải bị đóng.	Cập nhật lên phiên bản 9.0.90, 10.1.25, 11.0.0-M21 hoặc mới hơn.
		tcp/443	Apache Tomcat Multiple Vulnerabilities (Jun 2025) - Linux	Cao	Apache Tomcat is prone to multiple vulnerabilities. The following flaws exist: - CVE-2025-48976: Denial of service (DoS) in Apache Commons FileUpload - CVE-2025-48988:DoS in multipart upload	Update to version 9.0.106, 10.1.42, 11.0.8 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2025-49125: Security constraint bypass for pre/postresources	
		tcp/443	Apache Tomcat Multiple DoS Vulnerabilities (Jul 2025) - Linux	Cao	Apache Tomcat is prone to multiple denial of service (DoS) vulnerabilities. The following flaws exist: - CVE-2025-52520: DoS due to overflow in file upload limit - CVE-2025-53506: DoS via excessive HTTP/2 streams	Update to version 9.0.107, 10.1.43, 11.0.9 or later.
		tcp/443	Apache Tomcat DoS Vulnerability (Jul 2025) - Linux	Cao	Apache Tomcat is prone to a denial of service (DoS) vulnerability. A race condition on connection close could trigger a JVM crash when using the APR/Native connector leading to a DoS. This was particularly noticeable with client initiated closes of HTTP/2 connections.	Update to version 9.0.107 or later.
		tcp/443	Apache Tomcat Multiple Vulnerabilities (Oct 2023) - Linux	Cao	Apache Tomcat tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau đây: - CVE-2023-42795: Khi tái sử dụng (recycling) nhiều đối tượng nội bộ, bao gồm request và response, trước	Cập nhật lên phiên bản 8.5.94, 9.0.81, 10.1.14, 11.0.0-M12 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					khi tái sử dụng bởi request/response tiếp theo, lỗi có thể khiến cho Tomcat bỏ qua một số phần của quá trình tái sử dụng, dẫn đến rò rỉ thông tin từ request/response hiện tại sang request/response tiếp theo. - CVE-2023-44487: HTTP/2 rapid reset attack - CVE-2023-45648: Một header trailer không hợp lệ được tạo thủ công một cách đặc biệt có thể khiến cho Tomcat coi một request đơn lẻ như nhiều request, dẫn đến khả năng tấn công request smuggling khi ở phía sau một reverse proxy.	
		tcp/443	Apache Tomcat HTTP/2 Protocol DoS Vulnerability (MadeYouReset) - Linux	Cao	Apache Tomcat is prone to is prone to a denial of service (DoS) vulnerability in the HTTP/2 protocol dubbed 'MadeYouReset'. A mismatch caused by client-triggered server-sent stream resets between HTTP/2 specifications and the internal architectures of some HTTP/2 implementations may result	Update to version 9.0.108, 10.1.44, 11.0.10 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					in excessive server resource consumption leading to denial-of-service (DoS). By opening streams and then rapidly triggering the server to reset them, using malformed frames or flow control errors, an attacker can exploit incorrect stream accounting. Streams reset by the server are considered closed at the protocol level, even though backend processing continues. This allows a client to cause the server to handle an unbounded number of concurrent streams on a single connection.	
		tcp/443	Apache Tomcat Request Mix-up Vulnerability (May 2022) - Linux	Cao	Apache Tomcat tồn tại lỗ hổng request mix-up. Nếu một ứng dụng web gửi một thông điệp WebSocket đồng thời với việc đóng kết nối WebSocket, ứng dụng đó có thể tiếp tục sử dụng socket sau khi nó đã bị đóng. Việc xử lý lỗi được kích hoạt trong trường hợp này có thể khiến cho một đối tượng trong bộ nhớ đệm (pooled object) được thêm vào bộ đệm hai lần. Điều này có thể dẫn đến các kết nối tiếp theo	Cập nhật lên phiên bản 8.5.76, 9.0.21 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					sử dụng cùng một đối tượng đồng thời, có thể dẫn đến việc dữ liệu được trả về cho người dùng sai và/hoặc các lỗi khác.	
		tcp/443	jQuery End of Life (EOL) Detection - Linux	Trung bình	Phiên bản jQuery trên thiết bị từ xa đã đến cuối chu kỳ hỗ trợ (EOL) và không nên được sử dụng nữa.	Cập nhật jQuery trên thiết bị từ xa lên một phiên bản vẫn được hỗ trợ.
		tcp/443	Apache Tomcat Open Redirect Vulnerability (Aug 2023) - Linux	Trung bình	Apache Tomcat tồn tại lỗ hổng open redirect. Nếu ứng dụng web ROOT (mặc định) được cấu hình để sử dụng FORM authentication thì một URL được tạo thủ công một cách đặc biệt có thể được sử dụng để kích hoạt chuyển hướng đến một URL do kẻ tấn công chọn.	Cập nhật lên phiên bản 8.5.93, 9.0.80, 10.1.13, 11.0.0-M11 hoặc mới hơn.
		tcp/443	Apache Tomcat Authentication Bypass Vulnerability (Nov 2024) - Linux	Trung bình	Apache Tomcat is prone to an authentication bypass vulnerability. If Tomcat was configured to use a custom Jakarta Authentication (formerly JASPIC) ServerAuthContext component which may throw an exception during the authentication process without explicitly setting an	Update to version 9.0.96, 10.1.31, 11.0.0 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					HTTP status to indicate failure, the authentication may not have failed, allowing the user to bypass the authentication process. There are no known Jakarta Authentication components that behave in this way.	
		tcp/443	Apache Axis <= 1.4 Multiple Vulnerabilities	Trung bình	Apache Axis tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau: - CVE-2012-5784: Vượt qua xác thực SSL certificate - CVE-2014-3596: Xác thực chứng thư không an toàn - CVE-2018-8032: Cross-site scripting (XSS) trong default servlet/services - CVE-2019-0227: Server-side request forgery (SSRF) - CVE-2023-40743: Thực thi mã từ xa (RCE) - CVE-2023-51441: SSRF	Nhà cung cấp không đưa ra giải pháp. Các tùy chọn giải pháp chung là nâng cấp lên bản phát hành mới hơn, vô hiệu hóa các tính năng tương ứng, gỡ bỏ sản phẩm hoặc thay thế sản phẩm bằng sản phẩm khác. Lưu ý: - Axis 1 đã ngừng hỗ trợ (EOL) và nhà cung cấp khuyến nghị chuyển sang một SOAP engine khác, chẳng hạn như Apache Axis2/Java - Phiên bản 1.4 được phát hành vào ngày 22 tháng 4 năm 2006 và một số lỗ hổng chỉ được sửa trong SVN repository, có thể được sử dụng để giảm thiểu các lỗ hổng này - Dự án Apache Axis không dự định phát hành Axis 1.x để khắc phục các lỗ hổng này - Nếu bản cài đặt từ xa được build từ SVN sources hoặc được bảo vệ bằng 'backports' của một bản phân phối Linux, hãy tạo một bản ghi đè (override) cho kết quả này
		tcp/443	Apache Tomcat Information Disclosure Vulnerability (Mar 2023) - Linux	Trung bình	Apache Tomcat tồn tại một lỗ hổng tiết lộ thông tin (information disclosure).	Cập nhật lên phiên bản 8.5.86, 9.0.72, 10.1.6, 11.0.0-M3 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Khi sử dụng RemoteIpFilter với các yêu cầu nhận được từ một reverse proxy thông qua HTTP bao gồm header XForwarded-Proto được đặt thành https, các cookie phiên (session cookie) được tạo bởi Tomcat không bao gồm thuộc tính secure. Điều này có thể dẫn đến việc user agent truyền cookie phiên qua một kênh không an toàn.	
		tcp/443	Apache Tomcat Multiple DoS Vulnerabilities (Mar 2024) - Linux	Trung bình	Apache Tomcat tồn tại nhiều lỗ hổng từ chối dịch vụ (DoS). Tồn tại các lỗ hổng sau đây: - CVE-2024-23672: WebSocket DoS với quá trình đóng kết nối (closing handshake) không hoàn chỉnh - CVE-2024-24549: HTTP/2 header handling DoS	Cập nhật lên phiên bản 8.5.99, 9.0.86, 10.1.19, 11.0.0-M17 hoặc mới hơn.
		tcp/443	Apache Tomcat Multiple Vulnerabilities (Dec 2024) - Linux	Trung bình	Apache Tomcat is prone to multiple vulnerabilities. The following flaws exist: - CVE-2024-50379:Remote code execution (RCE) via write-enabled default servlet - CVE-2024-54677:Denial of service (DoS) in examples web application	Update to version 9.0.98, 10.1.34, 11.0.2 or later. Vendor note: Users running Tomcat on a case insensitive file system with the default servlet write enabled (readonly initialisation parameter set to the non-default value of false) may need additional configuration to fully mitigate CVE-2024-

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2024-56337:RCE via writeenabled default servlet - CVE-2024-50379 mitigation was incomplete	50379 depending on which version of Java they are using with Tomcat: - running on Java 8 or Java 11: the system property sun.io.useCanonCaches must be explicitly set to false (it defaults to true) - running on Java 17: the system property sun.io.useCanonCaches, if set, must be set to false (it defaults to false) - running on Java 21 onwards: no further configuration is required (the system property and the problematic cache have been removed)
		tcp/443	Apache Tomcat DoS Vulnerability (Oct 2021) - Linux	Trung bình	Apache Tomcat tồn tại lỗ hổng từ chối dịch vụ (DoS). Bản sửa lỗi cho lỗi 63362 đã gây ra lỗi rò rỉ bộ nhớ (memory leak). Đối tượng được thêm vào để thu thập số liệu cho các kết nối HTTP upgrade không được giải phóng đối với các kết nối WebSocket khi kết nối WebSocket bị đóng. Điều này gây ra lỗi rò rỉ bộ nhớ, theo thời gian có thể dẫn đến từ chối dịch vụ thông qua OutOfMemoryError.	Cập nhật lên phiên bản 8.5.72, 9.0.54, 10.0.12, 10.1.0-M6 hoặc mới hơn.
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
			Vulnerability (SSL/TLS, D(HE)ater)		đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích	Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/443	Apache Tomcat CGI Security Constraint Bypass Vulnerability (May 2025) - Linux	Trung bình	When running on a case insensitive file system with security constraints configured for the <code>pathInfo</code> component of a URL that mapped to the CGI servlet, it is possible to bypass those	Update to version 9.0.105, 10.1.41, 11.0.7 or later.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					security constraints with a specially crafted URL.	
		tcp/443	Apache Tomcat Clustering DoS Vulnerability (May 2022)	Trung bình	Apache Tomcat tồn tại lỗ hổng từ chối dịch vụ (DoS) khi chạy với Tomcat clustering được bật trên một mạng không đáng tin cậy. Tài liệu cho EncryptInterceptor đã nêu sai rằng nó cho phép Tomcat clustering chạy trên một mạng không đáng tin cậy. Điều này không chính xác. Mặc dù EncryptInterceptor cung cấp bảo vệ tính bí mật và tính toàn vẹn nhưng nó không bảo vệ khỏi tất cả các rủi ro liên quan đến việc chạy trên bất kỳ mạng không đáng tin cậy nào, đặc biệt là các rủi ro DoS.	- Không chạy Apache Tomcat với Tomcat clustering được bật trên một mạng không đáng tin cậy - Cập nhật Apache Tomcat lên phiên bản 10.1.0-M15, 10.0.21, 9.0.63, 8.5.79 hoặc mới hơn để nhận được tài liệu đã được sửa lại / cập nhật
		tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST)	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	
		tcp/443	SSL/TLS: BREACH attack against HTTP compression	Trung bình	Các kết nối SSL/TLS có thể bị tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext). Angelo Prado, Neal Harris và Yoel Gluck đã báo cáo rằng các cuộc tấn công SSL/TLS vẫn khả thi thông qua tấn công 'BREACH' (Browser Reconnaissance & Exfiltration via Adaptive Compression of Hypertext), được họ mô tả như sau: Trong khi CRIME đã được khắc phục bằng cách vô hiệu hóa TLS/SPDY compression (và bằng cách sửa đổi gzip để cho phép tách riêng các ngữ cảnh nén (compression context) một cách rõ ràng trong SPDY) thì BREACH tấn công các HTTP response. Chúng được nén bằng HTTP compression phổ biến, phổ biến hơn nhiều so với TLS-level compression. Điều này về cơ bản cho phép thực hiện	Có các khả năng giảm thiểu rủi ro sau đây: 1. Vô hiệu hóa HTTP compression 2. Tách các bí mật khỏi đầu vào của người dùng 3. Ngẫu nhiên hóa các bí mật theo từng yêu cầu 4. Che giấu các bí mật (ngẫu nhiên hóa hiệu quả bằng cách XOR với một bí mật ngẫu nhiên theo từng yêu cầu) 5. Bảo vệ các trang có lỗ hổng bằng CSRF 6. Che giấu độ dài (bằng cách thêm một số byte ngẫu nhiên vào các phản hồi) 7. Giới hạn tốc độ các yêu cầu Lưu ý: Các biện pháp giảm thiểu được sắp xếp theo mức độ hiệu quả (không phải theo tính thực tế - vì điều này có thể khác nhau tùy theo từng ứng dụng).

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					cuộc tấn công tương tự như Duong và Rizzo đã chứng minh nhưng không phụ thuộc vào TLS-level compression (như họ dự đoán). Cần lưu ý rằng tấn công này không phụ thuộc vào phiên bản của TLS/SSL và không yêu cầu TLSlayer compression. Ngoài ra, tấn công này hoạt động với mọi hệ mật (cipher suite). Đối với một hệ mật dòng (stream cipher), tấn công đơn giản hơn: Sự khác biệt về kích thước giữa các phần thân của response chi tiết hơn nhiều trong trường hợp này. Nếu sử dụng một hệ mật khối (block cipher), cần phải thực hiện thêm các thao tác để căn chỉnh đầu ra với các khối bản mã (cipher text block).	
		tcp/443	jQuery < 3.0.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS). Khi một yêu cầu Ajax xuyên miền (cross-domain) được thực hiện mà không có tùy chọn dataType, sẽ khiến cho các phản hồi text/javascript được thực thi.	Cập nhật lên phiên bản 3.0.0 hoặc mới hơn.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	jQuery < 3.4.0 Object Extensions Vulnerability	Trung bình	jQuery tồn tại nhiều lỗ hổng liên quan đến việc chèn thuộc tính vào Object.prototype. Tồn tại các lỗ hổng sau đây: - CVE-2019-5428: Một lỗ hổng prototype pollution cho phép kẻ tấn công chèn các thuộc tính vào Object.prototype. - CVE-2019-11358: jQuery xử lý không đúng cách jQuery.extend(true, {}, ...) do Object.prototype bị chèn thêm (Object.prototype pollution). Nếu một đối tượng nguồn chưa được kiểm duyệt có chứa một thuộc tính __proto__ có thể liệt kê (enumerable), nó có thể mở rộng (extend) Object.prototype gốc.	Cập nhật lên phiên bản 3.4.0 hoặc mới hơn. Các bản vá lỗi (patch diff) có sẵn cho các phiên bản cũ hơn.
		tcp/443	jQuery 1.2 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) trong jQuery.htmlPrefilter và các phương thức liên quan. Việc truyền HTML từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery	Cập nhật lên phiên bản 3.5.0 trở lên.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					(ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	
		tcp/443	jQuery 1.0.3 < 3.5.0 XSS Vulnerability	Trung bình	jQuery tồn tại lỗ hổng cross-site scripting (XSS) khi thêm (append) HTML chứa các phân tử option. Việc truyền HTML chứa các phân tử <option> từ các nguồn không đáng tin cậy - ngay cả sau khi đã làm sạch (sanitizing) - vào một trong các phương thức thao tác DOM của jQuery (ví dụ: .html(), .append() và các phương thức khác) có thể thực thi mã không đáng tin cậy.	Cập nhật lên phiên bản 3.5.0 trở lên.
		tcp/443	Apache Tomcat XSS Vulnerability (Jun 2022) - Linux	Trung bình	Apache Tomcat tồn tại lỗ hổng cross-site scripting (XSS). Ví dụ về Form authentication trong ứng dụng web examples đã hiển thị dữ liệu do người dùng cung cấp mà không qua kiểm duyệt, dẫn đến lỗ hổng XSS.	Cập nhật lên phiên bản 8.5.82, 9.0.65, 10.0.23, 10.1.0-M17 hoặc mới hơn.
10	103.178.214.161	tcp/443	Microsoft Exchange Server 2019 EOP Vulnerability (KB5035606) -	Nghiêm trọng	Microsoft Exchange Server tồn tại một lỗ hổng leo thang đặc quyền (EOP).	Nhà cung cấp đã phát hành các bản cập nhật. Vui lòng xem các liên kết tham chiếu để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
			Unreliable Remote Version Check		Kẻ tấn công có thể nhắm mục tiêu vào một NTLM client như Outlook với lỗ hổng làm rò rỉ thông tin xác thực NTLM. Thông tin xác thực bị rò rỉ sau đó có thể được chuyển tiếp (relay) tới máy chủ Exchange để giành quyền như client nạn nhân và thực hiện các thao tác trên máy chủ Exchange thay mặt cho nạn nhân.	
		tcp/443	Microsoft Exchange Server 2016 / 2019 RCE Vulnerability (KB5036402, KB5036386, KB5036401) - Unreliable Remote Version Check	Nghiêm trọng	Microsoft Exchange Server tồn tại một lỗ hổng thực thi mã từ xa (RCE). Để thực hiện tấn công này, cần phải đặt một tệp được tạo thủ công một cách đặc biệt vào một thư mục trực tuyến hoặc trong một vị trí mạng cục bộ. Khi nạn nhân chạy tệp này, nó sẽ tải DLL độc hại.	Nhà cung cấp đã phát hành bản cập nhật. Vui lòng xem các liên kết tham chiếu để biết thêm thông tin.
		tcp/443	Microsoft Exchange Server OWA Multiple Vulnerabilities (KB5019758, ProxyNotShell) - Active Check	Nghiêm trọng	Microsoft Exchange Server tồn tại nhiều lỗ hổng trong Outlook Web App (OWA), được gọi chung là 'ProxyNotShell'. Tồn tại các lỗ hổng sau: - CVE-2022-41040: Lỗ hổng Server-SideRequest Forgery (SSRF)	- Áp dụng bản cập nhật KB5019758 do nhà cung cấp cung cấp hoặc - Áp dụng các bước giảm thiểu rủi ro được cung cấp bởi nhà cung cấp trong bài đăng blog được liên kết Lưu ý: - Hãy đảm bảo áp dụng các khuyến nghị giảm thiểu mới nhất vì chúng đã được cập nhật nhiều lần.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					- CVE-2022-41082: Thực thi mã từ xa (RCE) khi PowerShell có thể truy cập được bởi kẻ tấn công Một trong các lỗ hổng tồn tại trong điểm cuối (endpoint) 'autodiscover/autodiscover.json' của OWA và hiện đang được khai thác bởi một chiến dịch tấn công mới để thực thi mã từ xa trên mục tiêu bị ảnh hưởng. Xem các liên kết tham chiếu để biết thêm chi tiết kỹ thuật và chỉ báo bị xâm nhập (IOCs).	- Hãy tạo một bản ghi đè (override) cho kết quả này nếu bản cập nhật KB5019758 đã được áp dụng vì một số cấu hình / môi trường cụ thể vẫn có thể được báo cáo là có lỗ hổng (biểu thị bằng QoD thấp hơn là 70%/remote_analysis đối với VT này).
		tcp/443	Microsoft Exchange Server 2016 / 2019 Spoofing Vulnerability (KB5044062) - Unreliable Remote Version Check	Cao	Microsoft Exchange Server is prone to a spoofing vulnerability.	The vendor has released updates. Please see the references for more information.
		tcp/443	Microsoft Exchange Server 2016 / 2019 Improper Authentication Vulnerability (KB5050672, KB5050673, KB5050674) - Unreliable Remote Version Check	Trung bình	Microsoft Exchange Server is prone to an improper authentication vulnerability. An attacker with admin privileges on an on-premise Exchange server can potentially forge or manipulate trusted tokens or API calls that the cloud side will accept as legitimate.	The vendor has released updates. Please see the references for more information.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret. - Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/587	SMTP Unencrypted Cleartext Login	Trung bình	Thiết bị từ xa đang chạy một máy chủ SMTP cho phép đăng nhập rõ ràng (cleartext) qua các kết nối không được mã hóa.	Bật SMTPS hoặc buộc kết nối thông qua lệnh 'STARTTLS'. Vui lòng xem hướng dẫn của máy chủ SMTP để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		Tcp/110	POP3 Unencrypted Cleartext Login	Trung bình	Máy chủ từ xa đang chạy daemon POP3 cho phép đăng nhập bằng văn bản rõ (cleartext) qua các kết nối không được mã hóa. LƯU Ý: Tùy thuộc vào cấu hình máy chủ POP3, thông tin xác thực hợp lệ cần được cung cấp cho cài đặt OID 'Login configurations': 1.3.6.1.4.1.25623.1.0.10870.	Cấu hình máy chủ từ xa để luôn buộc kết nối mã hóa qua SSL/TLS bằng lệnh 'STLS'.
		Tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.
11	103.178.214.185	tcp/443	Nginx End of Life (EOL) Detection	Nghiêm trọng	Phiên bản Nginx trên máy chủ từ xa đã đến cuối chu kỳ hỗ trợ (End of Life - EOL) và không nên được sử dụng nữa.	Cập nhật phiên bản Nginx trên máy chủ từ xa lên một phiên bản được hỗ trợ.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
		tcp/443	nginx <= 1.21.1 Information Disclosure Vulnerability	Cao	nginx tồn tại lỗ hổng tiết lộ thông tin (information disclosure). Cấu hình mặc định của nginx sử dụng các quyền truy cập world-readable cho các tệp access.log và error.log, cho phép người dùng cục bộ thu thập thông tin nhạy cảm bằng cách đọc các tệp.	Không có giải pháp nào được công bố trong ít nhất một năm kể từ khi phát hành lỗ hổng này. Có khả năng sẽ không có giải pháp nào được cung cấp nữa. Các tùy chọn giải pháp chung là nâng cấp lên bản phát hành mới hơn, vô hiệu hóa các tính năng tương ứng, gỡ bỏ sản phẩm hoặc thay thế sản phẩm bằng sản phẩm khác.
		tcp/443	Nginx Multiple Vulnerabilities (Oct 2022)	Trung bình	Nginx tồn tại nhiều lỗ hổng. Tồn tại các lỗ hổng sau: - CVE-2022-41741: Kẻ tấn công có thể khiến cho tiến trình worker bị crash hoặc bộ nhớ của tiến trình worker bị lỗi bằng cách sử dụng một tệp mp4 đặc biệt. - CVE-2022-41742: Kẻ tấn công có thể khiến cho tiến trình worker bị crash hoặc tiết lộ bộ nhớ của tiến trình worker bằng cách sử dụng một tệp mp4 đặc biệt.	Cập nhật lên phiên bản 1.22.1, 1.23.2 trở lên.
		tcp/443	Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSL/TLS, D(HE)ater)	Trung bình	Máy chủ SSL/TLS từ xa đang hỗ trợ các thuật toán DiffieHellman ephemeral (DHE) Key Exchange và do đó có thể tồn tại lỗ hổng từ chối dịch vụ (DoS). - CVE-2002-20001: Giao thức Diffie-Hellman Key	- Nên vô hiệu hóa trao đổi khóa DHE nếu không thể sử dụng cơ chế giảm thiểu rủi ro nào khác và các client hỗ trợ trao đổi khóa bằng elliptic-curve variant of Diffie-Hellman (ECDHE) hoặc RSA. Cần xem xét thực tế là trao đổi khóa RSA không có tính năng forward secret.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Agreement cho phép kẻ tấn công từ xa (từ phía client) gửi các số tùy ý không thực sự là khóa công khai và kích hoạt các phép tính lũy thừa mô-đun DHE tốn kém tài nguyên ở phía máy chủ, còn được gọi là tấn công D(HE)ater. Client cần rất ít tài nguyên CPU và băng thông mạng. Tấn công có thể gây ảnh hưởng nghiêm trọng hơn trong trường hợp client có thể yêu cầu máy chủ chọn kích thước khóa lớn nhất được hỗ trợ. Kích bản tấn công cơ bản là client phải tuyên bố rằng nó chỉ có thể giao tiếp bằng DHE và máy chủ phải được cấu hình cho phép DHE. - CVE-2022-40735: Giao thức Diffie-Hellman Key Agreement cho phép sử dụng các số mũ dài vốn dĩ làm cho một số tính toán trở nên tốn kém một cách không cần thiết, bởi vì bài báo năm 1996 của van Oorschot và Wiener đã chỉ ra rằng có thể sử dụng 'số mũ ngắn (thích hợp)' khi có các ràng buộc nhóm con (subgroup) phù hợp và các số mũ ngắn này có thể dẫn đến tính toán ít tốn	- Giới hạn số lượng kết nối đồng thời tối đa trong cấu hình của máy chủ từ xa. Đối với Postfix, giới hạn này có thể được cấu hình thông qua tùy chọn 'smtpd_client_new_tls_session_rate_limit', đối với các sản phẩm khác, vui lòng tham khảo hướng dẫn sử dụng của sản phẩm đó để biết các khả năng cấu hình.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					kém hơn so với số mũ dài. Vấn đề này khác với CVE-200220001 vì nó dựa trên quan sát về kích thước số mũ thay vì quan sát về các số không phải là khóa công khai. Các tình huống cụ thể trong đó chi phí tính toán có thể cấu thành một lỗ hổng ở phía máy chủ phụ thuộc vào giao thức (ví dụ: TLS, SSH hoặc IKE) và các chi tiết triển khai DHE. Nói chung, có thể có lo ngại về tính khả dụng do việc tiêu thụ tài nguyên ở phía máy chủ từ các phép tính lũy thừa môđun DHE. Cuối cùng, kẻ tấn công có thể khai thác lỗ hổng này cùng với CVE-2002-20001.	
		tcp/443	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Trung bình	Có thể phát hiện việc sử dụng giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời trên hệ thống này. Các giao thức TLSv1.0 và TLSv1.1 chứa các lỗ hổng mật mã đã biết như: - CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST) - CVE-2015-0204: Factoring Attack on RSA-EXPORT	Khuyến cáo nên vô hiệu hóa các giao thức TLSv1.0 và/hoặc TLSv1.1 đã lỗi thời thay bằng các giao thức TLSv1.2+. Vui lòng xem các tham chiếu để biết thêm thông tin.

#	Host	Cổng dịch vụ	Nguy cơ	Mức độ	Mô tả	Khuyến nghị
					Keys Padding Oracle On Downgraded LegacyEncryption (FREAK)	
		tcp/443	Nginx 1.11.4 - 1.27.3 TLS Session Resumption Vulnerability	Trung bình	Nginx is prone to a TLS session resumption vulnerability. When name-based virtual hosts are configured to share the same IP address and port combination, with TLS 1.3 and OpenSSL, a previously authenticated attacker can use session resumption to bypass client certificate authentication requirements on these servers. This vulnerability arises when TLS session tickets are used and/or the SSL session cache is used in the default virtual server and the default virtual server is performing client certificate authentication. This issue affects both the NGINX http and NGINX stream modules.	Update to version 1.26.3, 1.27.4 or later.

PHỤ LỤC 3. LỘ LỘT TÀI KHOẢN

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
1	https://imis.evn.com.vn	001000589459	f****b	Đăng nhập không thành công
2	https://hrms.evn.com.vn	manpv.bl@evnspc.vn	M*****#	Đăng nhập không thành công
3	https://elearning.evn.com.vn	86000000000103	#*****t	Đăng nhập không thành công
4	https://elearning.evn.com.vn	hoangvantuong@gmail.com	H*****1	Đăng nhập không thành công
5	https://elearning.evn.com.vn	27043	H*****1	Đăng nhập không thành công
6	https://elearning.evn.com.vn	leothuy159@gmail.com	E*****9	Đăng nhập không thành công
7	https://elearning.evn.com.vn	20995	H*****1	Đăng nhập không thành công
8	https://elearning.evn.com.vn	33294	H*****1	Đăng nhập không thành công
9	https://elearning.evn.com.vn	vothienhuy@gmail.com	@*****8	Đăng nhập không thành công
10	https://imis.evn.com.vn	cukhacsinh1986@gmail.com	Q*****9	Đăng nhập không thành công
11	https://imis.evn.com.vn	quangnhut@gmail.com	Q*****9	Đăng nhập không thành công
12	https://elearning.evn.com.vn	dung5nt@hcmptc.com.vn	H*****1	Đăng nhập không thành công
13	https://elearning.evn.com.vn	Danhdt@hcmptc.com.vn	K*****1	Đăng nhập không thành công
14	https://elearning.evn.com.vn	Huongtd	h*****5	Đăng nhập không thành công
15	https://elearning.evn.com.vn	483000000000314	D*****4	Đăng nhập không thành công
16	https://elearning.evn.com.vn	17142	H*****8	Đăng nhập không thành công
17	https://elearning.evn.com.vn	18789	H*****8	Đăng nhập không thành công
18	https://elearning.evn.com.vn	18748	9*****q	Đăng nhập không thành công
19	https://elearning.evn.com.vn	25148	H*****8	Đăng nhập không thành công
20	https://elearning.evn.com.vn	18748	H*****8	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
21	https://elearning.evn.com.vn	22616	H*****8	Đăng nhập không thành công
22	https://elearning.evn.com.vn	14623	H*****8	Đăng nhập không thành công
23	https://elearning.evn.com.vn	277000000009011	H*****1	Đăng nhập không thành công
24	https://elearning.evn.com.vn	danhdt@hcmptc.com.vn	h*****8	Đăng nhập không thành công
25	https://imis.evn.com.vn	chungocthuy@npt.com.vn	E*****8	Đăng nhập không thành công
26	https://imis.evn.com.vn	luuvanhung@npt.com.vn	E*****8	Đăng nhập không thành công
27	https://elearning.evn.com.vn	hoangvantruong10101963@gmail.com	1****6	Đăng nhập không thành công
28	https://elearning.evn.com.vn	483000000000043	D*****4	Đăng nhập không thành công
29	https://imis.evn.com.vn	dautuphatnienait@gmail.com	A*****3	Đăng nhập không thành công
30	https://imis.evn.com.vn	nguyenvietkhoa35@gmail.com	A*****3	Đăng nhập không thành công
31	https://imis.evn.com.vn	k44.pvc@gmail.com	T*****7	Đăng nhập không thành công
32	https://elearning.evn.com.vn	hungdt.ptc1@gmail.com	h*****8	Đăng nhập không thành công
33	https://imis.evn.com.vn	mrngocanh1905@gmail.com	A*****3	Đăng nhập không thành công
34	https://imis.evn.com.vn	than75990@gmail.com	A*****3	Đăng nhập không thành công
35	https://elearning.evn.com.vn	1319000000000650	@*****6	Đăng nhập không thành công
36	https://elearning.evn.com.vn	truongvm@npt.evn.vn	h*****8	Đăng nhập không thành công
37	https://imis.evn.com.vn	thaiquockhanh@npt.com.vn	E*****8	Đăng nhập không thành công
38	https://elearning.evn.com.vn	ngocvan7274.ptc3@npt.evn.vn	C*****9	Đăng nhập không thành công
39	https://elearning.evn.com.vn	Bangnl@hcmptc.com.vn	H*****1	Đăng nhập không thành công
40	https://imis.evn.com.vn	tranphilong977404@gmail.com	Q*****4	Đăng nhập không thành công
41	imis.evn.com.vn/	Ngonnd.BK	B*****5	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
42	elearning.evn.com.vn/	nguyenthingocdltp@gmail.com	h*****8	Đăng nhập không thành công
43	https://imis.evn.com.vn/login	1npt\nguyenphuhai	p*****5	Đăng nhập không thành công
44	https://imis.evn.com.vn/login	1npt\nguyenphuhai	p*****4	Đăng nhập không thành công
45	https://elearning.evn.com.vn	239000000001252	T*****3	Đăng nhập không thành công
46	https://elearning.evn.com.vn	sangmt@hcmipc.com.vn	h*****8	Đăng nhập thành công
47	https://elearning.evn.com.vn	cans@hcmipc.com.vn	h*****8	Đăng nhập không thành công
48	elearning.evn.com.vn	0347516432	b*****@	Đăng nhập không thành công
49	elearning.evn.com.vn	32998	h*****8	Đăng nhập không thành công
50	elearning.evn.com.vn	31074	M*****@	Đăng nhập không thành công
51	elearning.evn.com.vn	chi2nm@hcmipc.com.vn	h*****i	Đăng nhập không thành công
52	elearning.evn.com.vn	huynhcoi3737@gmail.com	H*****7	Đăng nhập không thành công
53	https://elearning.evn.com.vn	ngoquangdien@gmail.com	d*****#	Đăng nhập không thành công
54	https://elearning.evn.com.vn	tuan6nv@hcmipc.com.vn	h*****8	Đăng nhập không thành công
55	elearning.evn.com.vn/login	tuttut1112@gmail.com	Q*****a	Đăng nhập không thành công
56	elearning.evn.com.vn/login	PC12AA0154874	0****0	Đăng nhập không thành công
57	smis.evn.com.vn/sign-in	sonla	T*****@	Đăng nhập không thành công
58	elearning.evn.com.vn/login	4742836	a***n	Đăng nhập không thành công
59	doffice.evn.com.vn/sign-in	Pablo	a*****9	Đăng nhập không thành công
60	elearning.evn.com.vn	ngadnh@hcmipc.com.vn	q*****5	Đăng nhập thành công
61	elearning.evn.com.vn/login	chuanpv	C*****0	Đăng nhập không thành công
62	elearning.evn.com.vn/	SPC4	D*****\$	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
63	elearning.evn.com.vn/login	43696727Q	8*****	Đăng nhập không thành công
64	https://analytics.evn.com.vn/	ducpc	V*****4	Đăng nhập không thành công
65	sudungdien.evn.com.vn/Home/Login	Quy3@2024*#	s***** **n	Đăng nhập không thành công
66	elearning.evn.com.vn/login	92000000005557	h*****1	Đăng nhập không thành công
67	elearning.evn.com.vn/login	TBA-SH-TC-B2_4	6**2	Đăng nhập không thành công
68	imis.evn.com.vn	0102658983	H*****6	Đăng nhập không thành công
69	imis.evn.com.vn	PD13000941323	Q*****4	Đăng nhập không thành công
70	elearning.evn.com.vn/login	202003504051	a*****s	Đăng nhập không thành công
71	elearning.evn.com.vn/login	SheLuvsConor	5***5	Đăng nhập không thành công
72	elearning.evn.com.vn/login	duc2nm@hcmpc.com.vn	H*****1	Đăng nhập không thành công
73	elearning.evn.com.vn/login	92000000005954	T*****1	Đăng nhập không thành công
74	https://imis.evn.com.vn:8089/login	huynhminhhieptaco@gmail.com	v*****X	Đăng nhập thành công
75	elearning.evn.com.vn	long.v47@gmail.com	S*****1	Đăng nhập không thành công
76	elearning.evn.com.vn/login	lehoanhthd@gmail.com	@*****9	Đăng nhập không thành công
77	sudungdien.evn.com.vn/home/login	TKDC06	D*****0	Đăng nhập không thành công
78	imis.evn.com.vn:8089/	phungthanhvulinh@gmail.com	p*****v	Đăng nhập không thành công
79	elearning.evn.com.vn/login	237000000001528	p*****!	Đăng nhập không thành công
80	elearning.evn.com.vn/login	224000000002670	1****6	Đăng nhập không thành công
81	elearning.evn.com.vn/login	236000000001522	V*****#	Đăng nhập không thành công
82	elearning.evn.com.vn/login	236000000000589	K*****#	Đăng nhập không thành công
83	elearning.evn.com.vn/login	13883	X*****1	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
84	elearning.evn.com.vn/login	224000000002669	D*****6	Đăng nhập không thành công
85	elearning.evn.com.vn/login	224000000002672	1*****@	Đăng nhập không thành công
86	elearning.evn.com.vn/login	236000000001516	T*****#	Đăng nhập không thành công
87	elearning.evn.com.vn/login	224000000000017	H*****4	Đăng nhập không thành công
88	elearning.evn.com.vn/login	224000000002852	1****6	Đăng nhập không thành công
89	elearning.evn.com.vn/login	224000000002671	T*****3	Đăng nhập không thành công
90	elearning.evn.com.vn/login	15548	S*****3	Đăng nhập không thành công
91	elearning.evn.com.vn/login	224000000002851	1****6	Đăng nhập không thành công
92	elearning.evn.com.vn/login	224000000002650	N*****4	Đăng nhập không thành công
93	elearning.evn.com.vn/login	31005	B*****@	Đăng nhập không thành công
94	elearning.evn.com.vn/login	12104	D*****6	Đăng nhập không thành công
95	imis.evn.com.vn:8089/login	longxinghieplamdong@gmail.com	L*****6	Đăng nhập thành công
96	imis.evn.com.vn:8089/login	huynhvanthao.ptp@gmail.com	Q*****3	Đăng nhập không thành công
97	giamsat.evn.com.vn/login	ngoctung.nguyen2408.ld@yahoo.com	E*****3	Đăng nhập không thành công
98	elearning.evn.com.vn/login	23545	T*****1	Đăng nhập không thành công
99	elearning.evn.com.vn/login	236000000001517	T*****#	Đăng nhập không thành công
100	elearning.evn.com.vn/login	224000000002675	1****6	Đăng nhập không thành công
101	elearning.evn.com.vn/login	224000000002670	N*****4	Đăng nhập không thành công
102	elearning.evn.com.vn/login	224000000002658	1****6	Đăng nhập không thành công
103	elearning.evn.com.vn/login	224000000002828	1****6	Đăng nhập không thành công
104	elearning.evn.com.vn/login	2024236006	E*****3	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
105	imis.evn.com.vn:8089/login	hoangvuxnld@gmail.com	Q*****5	Đăng nhập không thành công
106	elearning.evn.com.vn/login	224000000002820	H*****8	Đăng nhập không thành công
107	elearning.evn.com.vn/login	10055	h*****8	Đăng nhập không thành công
108	imis.evn.com.vn:8089/login	sonkthuat@gmail.com	1*****a	Đăng nhập không thành công
109	elearning.evn.com.vn/login	224000000002654	T*****3	Đăng nhập không thành công
110	imis.evn.com.vn:8089/	hoangvuxnld@gmail.com	Q*****5	Đăng nhập không thành công
111	elearning.evn.com.vn/login	224000000002625	T*****2	Đăng nhập không thành công
112	elearning.evn.com.vn/login	224000000002650	1****6	Đăng nhập không thành công
113	elearning.evn.com.vn/login	224000000002672	1****6	Đăng nhập không thành công
114	elearning.evn.com.vn	builamtungevn@gmail.com	B*****6	Đăng nhập không thành công
115	elearning.evn.com.vn/login	368000000000473	V*****7	Đăng nhập không thành công
116	imis.evn.com.vn/login	ngocdung.infor@gmail.com	N*****3	Đăng nhập không thành công
117	elearning.evn.com.vn/login	metaheat@hotmail.com	h*****1	Đăng nhập không thành công
118	imis.evn.com.vn:8089/login	ngocdung.infor@gmail.com	N*****3	Đăng nhập không thành công
119	https://elearning.evn.com.vn	luongbao114@gmail.com	1****6	Đăng nhập không thành công
120	https://elearning.evn.com.vn	375000000000182	T*****2	Đăng nhập không thành công
121	https://elearning.evn.com.vn/login	159000000000015	D*****@	Đăng nhập không thành công
122	elearning.evn.com.vn/login	242000000000850	p*****5	Đăng nhập không thành công
123	https://imis.evn.com.vn/	tranvanhau@gmail.com	H*****7	Đăng nhập không thành công
124	https://imis.evn.com.vn	nhathau1@gmail.com	Q*****4	Đăng nhập không thành công
125	elearning.evn.com.vn/login	chittn@evn2022.com	E*****2	Đăng nhập không thành công

#	Đường dẫn	Tên đăng nhập	Mật khẩu	Trạng thái của tài khoản
126	elearning.evn.com.vn/login	chittn@evn2021.com.vn	E*****1	Đăng nhập không thành công
127	https://elearning.evn.com.vn/login :	NPC\PhuongVTT	*****\$	Đăng nhập không thành công
128	https://elearning.evn.com.vn/login :	Npc\phuongVTT	*****8	Đăng nhập không thành công
129	https://imis.evn.com.vn/login :	NPC\PhuongVTT	*****@	Đăng nhập không thành công
130	https://elearning.evn.com.vn/login	DLTHAIBINH\THUTT	D*****	Đăng nhập không thành công
131	https://elearning.evn.com.vn/login	khanhtd.evnhn	E*****3	Đăng nhập không thành công
132	https://elearning.evn.com.vn/login	C27\THANHNB	H*****1	Đăng nhập không thành công
133	https://elearning.evn.com.vn/login	86000000000159	P*****4	Đăng nhập không thành công
134	https://elearning.evn.com.vn/login	duc.hv1992@gmail.com	V*****5	Đăng nhập thành công

PHỤ LỤC 4. LỘ LỘT TÀI LIỆU

(Không có dữ liệu)

#	Tên tài liệu	Kích thước	Đường dẫn	Thời gian ghi nhận

PHỤ LỤC 5. LẠM DỤNG THƯƠNG HIỆU

(Không có dữ liệu)

#	Tên	Mô tả	Giao diện

PHỤ LỤC 6. YÊU CẦU ĐIỀU TRA

(Không có dữ liệu)

#	Tên miền	Trạng thái	Thời gian yêu cầu	Thời gian hoàn thành

PHỤ LỤC 7. IP LIÊN QUAN MÃ ĐỘC/BOTNET

(Không có dữ liệu)

#	IP	Thời gian ghi nhận	Thông tin bổ sung

PHỤ LỤC 8. CHIẾN DỊCH TẤN CÔNG

(Các chiến dịch có thể ảnh hưởng đến tổ chức)

(Không có dữ liệu)

#	Tên chiến dịch	Mục tiêu		Thời gian ghi nhận
		Quốc gia	Lĩnh vực	

PHỤ LỤC 9. TÀI SẢN GIÁM SÁT

Trung tâm Dữ liệu (TTDL)

WAP Server VIP_IMIS

#	Tài sản	Mô tả
1	api-imis.evn.com.vn	
2	imis.evn.com.vn	

Gatewaysmg01

#	Tài sản	Mô tả
1	gatewaysmg01.evn.com.vn	

COAL-WEB

#	Tài sản	Mô tả
1	coalsso.evn.com.vn	

Gateway Doffice kết nối F5

#	Tài sản	Mô tả
1	doffice-new.evn.com.vn	

API Gateway Doffice kết nối F5

#	Tài sản	Mô tả
1	gwdoffice-new.evn.com.vn	

TTDL miền Nam

#	Tài sản	Mô tả
1	103.178.215.0/24	

Elearning VietAD 2

#	Tài sản	Mô tả
1	elearning-statics.evn.com.vn	

QLKHSRV01

#	Tài sản	Mô tả
1	beta2.evn.com.vn	
2	daotao.evn.com.vn	
3	www.hanoipc.evn.com.vn	
4	haiphongpc.evn.com.vn	
5	57hanoipc.evn.com.vn	
6	ww.haiphongpc.evn.com.vn	

Service Desk Plus tại DR

#	Tài sản	Mô tả
1	sdp1.evn.com.vn	

DNS Internet Windows

#	Tài sản	Mô tả
1	dns2.evn.com.vn	

Gateway01 (SMG38)

#	Tài sản	Mô tả
1	gateway38.evn.com.vn	

Portal Server

#	Tài sản	Mô tả

1	meeting1.evn.com.vn	
---	---------------------	--

HNTH

#	Tài sản	Mô tả
1	meeting2.evn.com.vn	

Elearning VietAD 1

#	Tài sản	Mô tả
1	elearning-api.evn.com.vn	
2	elearning.evn.com.vn	

WPM Player Internet

#	Tài sản	Mô tả
1	eoffice1.evnit.evn.vn	

IP 2 cấp Smart EVN kết nối F5

#	Tài sản	Mô tả
1	bugtracking.evnit.evn.com.vn	
2	jira.evn.vn	
3	smartevn-api.evn.com.vn	
4	smartevn1-api.evn.com.vn	

VIP kết nối F5 dải 125.214.0.224

#	Tài sản	Mô tả
1	chatecabinet.evn.vn	

Load Balancing cho EVNPortal kết nối F5

#	Tài sản	Mô tả
1	analytics.evn.com.vn	
2	apimds.evn.com.vn	

3	bcqt.evn.com.vn	
4	csdlmoitruong.evn.com.vn	
5	dhkd.evn.com.vn	
6	homebeta.evn.com.vn	
7	hrmsimage.evn.com.vn	
8	lichhop.evn.com.vn	
9	lichhop.evn.vn	
10	lichtuan.evn.com.vn	
11	lichtuan.evn.vn	
12	lichtuanict.evn.com.vn	
13	lichtuanict.evn.vn	
14	login.evn.com.vn	
15	mds.evn.com.vn	
16	messenger.evn.com.vn	
17	myaccount.evn.com.vn	
18	officeonline.evn.com.vn	
19	oosdev.evn.com.vn	
20	portal.evn.com.vn	
21	portaldev.evn.com.vn	
22	portalhelp.evn.com.vn	
23	portalservices.evn.com.vn	
24	portalservicesdev.evn.com.vn	
25	portalservicesuat.evn.com.vn	
26	portaluat.evn.com.vn	
27	xnbcgb.evn.com.vn	

28	pmis.evn.com.vn	
29	qlkt.evn.com.vn	

NAT máy chủ Email

#	Tài sản	Mô tả
1	webmail01.evn.vn	

DOFFICE-WEB

#	Tài sản	Mô tả
1	gwdoffice.evn.com.vn	

EVNPPA

#	Tài sản	Mô tả
1	ppa.evn.com.vn	

TTDL miền Bắc

#	Tài sản	Mô tả
1	103.178.214.0/24	

FTTH

#	Tài sản	Mô tả
1	117.6.160.162	
2	222.252.9.44	
3	222.252.15.96	
4	14.248.84.229	
5	14.248.84.105	
6	14.248.84.179	

7	117.6.160.195	
8	113.176.1.94	
9	113.190.46.74	
10	117.6.160.160	
11	222.252.9.124	
12	113.160.73.118	
13	117.6.160.164	
14	113.190.46.78	
15	115.73.223.66	
16	14.161.30.37	

F5 kết nối HRMS

#	Tài sản	Mô tả
1	hrms-new.evn.com.vn	

WAF Imperva

#	Tài sản	Mô tả
1	chat.evnit.evn.vn	
2	emobile-evnit.evn.com.vn	
3	eoffice.evnit.evn.vn	

F5 kết nối Smart EVN

#	Tài sản	Mô tả
1	smartevn.evn.com.vn	
2	smartevn1.evn.com.vn	

IP1 kết nối F5 dải 125.214.0.224

#	Tài sản	Mô tả
1	dofficedr.evn.com.vn	

evn portal test

#	Tài sản	Mô tả
1	logindr.evn.com.vn	
2	oosdr.evn.com.vn	
3	portaldr.evn.com.vn	
4	ortalservicesdr.evn.com.vn	

Sử dụng điện

#	Tài sản	Mô tả
1	evn-eoffice.evn.vn	
2	sudungdien.evn.com.vn	

WebEVNSrv02

#	Tài sản	Mô tả
1	binhchon.evn.com.vn	
2	icon.com.vn	
3	icon.evn.com.vn	
4	m.icon.com.vn	
5	nldc.evn.com.vn	
6	tinnganhdien.vn	
7	webdesign.evn.com.vn	
8	dauthau.evn.vn	
9	www.binhchon.evn.com.vn	
10	eptc.evn.com.vn	
11	www.eptc.evn.com.vn	
12	eptc.evn.vn	
13	www.eptc.evn.vn	

14	www.evnnews.vn	
15	www.icon.com.vn	
16	www.icon.evn.com.vn	
17	www.nldc.evn.com.vn	
18	www.tinnganhdien.vn	
19	www.vbpq.evn.com.vn	
20	nhatruythong.evn.com.vn	
21	www.nhatruythong.evn.com.vn	
22	vanhoa.evn.com.vn	
23	tietkiemnangluong.vn	
24	www.tietkiemnangluong.evn.com.vn	
25	tietkiemnangluong.evn.com.vn	
26	www.vanhoa.evn.com.vn	
27	dauthau.evn.com.vn	
28	evnnews.vn	
29	thietkeweb.evn.com.vn	
30	vbpq.evn.com.vn	

DOFFICE-OCELOT GW

#	Tài sản	Mô tả
1	doffice.evn.com.vn	

WAP Server 02_IMIS (IP virtual Server đang đặt trên F5)

#	Tài sản	Mô tả
1	imis123.evn.com.vn	

NGINX

#	Tài sản	Mô tả
---	---------	-------

1	dev.imis.evn.com.vn	
2	dev.imis.evn.vn	
3	imis-staging.evn.com.vn	
4	imis-staging.evn.vn	
5	imis-test.evn.com.vn	
6	imis-test.evn.vn	
7	imisstaging.evn.com.vn	
8	imistest.evn.com.vn	
9	openideal.evn.com.vn	
10	openideal.evnit.evn.com.vn	
11	openideal.evnit.evn.vn	
12	staging.imis.evn.com.vn	
13	staging.imis.evn.vn	

DMA Egde

#	Tài sản	Mô tả
1	call.evn.com.vn	
2	hnth.evn.com.vn	
3	meeting.evn.com.vn	
4	portalmeeting.evn.com.vn	
5	record.evn.com.vn	
6	schedule.evn.com.vn	
7	signin.evn.com.vn	
8	vc.evn.com.vn	
9	video.evn.com.vn	

Gateway29

#	Tài sản	Mô tả
1	gateway.akhpc.evn.vn	
2	gateway.evn.vn	
3	gateway.evnboimb.evn.vn	
4	gateway.evngenco2.evn.vn	
5	gateway.evnpm2.evn.vn	
6	gateway.hbinhpc.evn.vn	
7	gateway.ihpc.evn.vn	
8	gateway.thuctpc.evn.vn	
9	gateway.asonla.evn.vn	
10	gateway.hqbc.evn.vn	
11	mail1.evni.vn	
12	gateway.dongnaihpc.evn.vn	
13	gateway.npb.evn.vn	
14	gateway.ppc.evn.vn	
15	gateway.qntp.evn.com.vn	
16	gateway.tanpp.evn.vn	
17	gateway.tpccantho.evn.vn	
18	gateway.eptc.evn.vn	
19	gateway.lab.evn.vn	
20	gateway3.genco3.evn.vn	
21	gateway.evn.com.vn	
22	gateway.genco2.evn.vn	
23	gateway.hppc.evn.vn	
24	gateway.nppmb.evn.vn	

25	gateway.nps.evn.vn	
26	gateway.pmypp.evn.vn	
27	gateway.ptc1.evn.vn	
28	gateway.sppmb.evn.vn	
29	ateway.vinhthan4tpp.evn.vn	

NAT Email

#	Tài sản	Mô tả
1	autodiscover.evn.com.vn	
2	email.evn.com.vn	
3	email1.evn.com.vn	
4	emailnat.evn.com.vn	
5	imap.evn.vn	
6	mail.evn.com.vn	
7	mail.evn.vn	
8	owa.evn.vn	
9	pop3.evn.vn	
10	smtp.evn.vn	
11	webmail.evn.vn	

WEB SERVER EVN

#	Tài sản	Mô tả
1	m.tietkiemnangluong.vn	
2	www.tintuc.solar.evn.com.vn	
3	www1.evn.com.vn	
4	www1.tietkiemnangluong.vn	
5	www1.vanhua.evn.com.vn	

6	m.vanhua.evn.com.vn	
7	tintuc.solar.evn.com.vn	
8	webevnapi.evn.com.vn	
9	wslake.hochuathuydien.evn.com.vn	

WAP01- PORTAL-GE1

#	Tài sản	Mô tả
1	portal.evngenco1.vn	

Gateway01 (SMG)

#	Tài sản	Mô tả
1	gateway01.evn.com.vn	
2	gateway01.evn.vn	

EVNPortal Test/UAT

#	Tài sản	Mô tả
1	demo.evn.com.vn	
2	dtn.evn.vn	
3	emailssso.evn.com.vn	
4	evnfinance.evn.vn	
5	hdpc.evn.com.vn	
6	ievn.evn.com.vn	
7	ievn.evn.vn	
8	portallogin.evn.com.vn	
9	portaloos.evn.com.vn	
10	portalservicetest.evn.com.vn	
11	portaltest.evn.com.vn	
12	pwa.evn.com.vn	

13	tmhpc.evn.vn	
14	vnpd.evn.vn	
15	wap.evn.com.vn	
16	www.dtn.evn.vn	
17	www.evnfinance.evn.vn	
18	www.fmis.evn.com.vn	
19	www.fmis.evn.vn	
20	www.hdpc.evn.com.vn	
21	www.ievn.evn.com.vn	
22	www.ievn.evn.vn	
23	www.phumypc.evn.com.vn	
24	www.ppc.evn.com.vn	
25	www.vnpd.evn.vn	

Service Desk Plus

#	Tài sản	Mô tả
1	sdp.evn.com.vn	

Hệ thống F5 IP 1 kết nối Nginx Proxy

#	Tài sản	Mô tả
1	dtxd.evn.com.vn	
2	giamsat.evn.com.vn	
3	imis2.evn.com.vn	
4	imis2.evn.vn	
5	kdldd.evn.com.vn	
6	khcn.evn.com.vn	
7	ktat.evn.com.vn	

8	smartevn2.evn.com.vn	
9	qlnd.evn.com.vn	
10	smis.evn.com.vn	

EVNPORTAL-CHAT

#	Tài sản	Mô tả
1	chatonline.evn.com.vn	
2	icon1.evn.com.vn	

Help Doffice mobile-doffice.evn.com.vn

#	Tài sản	Mô tả
1	help.doffice.evn.com.vn	
2	help.evn.com.vn	
3	mobile-doffice.evn.com.vn	

EVNDNS

#	Tài sản	Mô tả
1	dns.evn.vn	
2	dns1.evn.com.vn	

FW-DMZ Port 1/11

#	Tài sản	Mô tả
1	vpn.evn.com.vn	

IP & Domain

#	Tài sản	Mô tả
1	mr.evn.com.vn	
2	emailsrv02.evn.com.vn	
3	fvp5kgw01.evn.com.vn	
4	evni.vn	

5	m.evnnews.vn	
6	media.evnnews.vn	
7	www.evni.vn	
8	dashboardqlkt.evn.com.vn	
9	eoffice.evn.com.vn	
10	eofficeict.evn.com.vn	
11	evnid-api.evn.com.vn	
12	hrmsws.evn.com.vn	
13	officedev.evn.com.vn	
14	tracuuhddt.evn.com.vn	
15	hrms.evn.com.vn	

Email Gateway

#	Tài sản	Mô tả
1	chatserver.evn.vn	
2	eoffice30.evn.vn	
3	hdtv.evn.com.vn	
4	hdtv.evn.vn	
5	lichtuan1.evn.vn	
6	service.eoffice.evn.vn	
7	emobile.evn.vn	
8	eoffice.evn.vn	
9	eoffice20.evn.vn	
10	eoffice30.evn.com.vn	
11	m.eoffice.evn.vn	

TKNLSRV03

#	Tài sản	Mô tả
1	atd6.evn.vn	
2	dauthauevn.evn.com.vn	
3	evc.evn.com.vn	
4	evnit.evn.com.vn	
5	evnit.vn	
6	authad.evn.com.vn	
7	pctt.evn.com.vn	
8	quyhoachdien.evn.com.vn	
9	sgi.evn.com.vn	
10	support.evn.com.vn	
11	uoc tinh diennang.evn.com.vn	
12	www.atd6.evn.vn	
13	www.dauthau.evn.com.vn	
14	www.evc.evn.com.vn	
15	www.evnit.vn	
16	www.support.evn.com.vn	
17	binhchonmauhoadontien dien.evn.com.vn	
18	doanthanh nien.evn.com.vn	
19	event.evn.com.vn	
20	evncti.evn.vn	
21	evnit.evn.vn	
22	lake.evn.com.vn	
23	www2.dauthau.evn.vn	
24	bulksms.evn.com.vn	

25	nghison1.evn.vn	
26	tudienkythuatdien.evn.com.vn	
27	daotaocanbo.evn.com.vn	
28	nhaan.evn.com.vn	
29	www.dauthau.evn.vn	
30	www.evnit.evn.com.vn	
31	www.evnit.evn.vn	
32	www.nghison1.evn.vn	

Hệ thống Email dự phòng

#	Tài sản	Mô tả
1	webmail.evn.com.vn	

WAF Viettel

#	Tài sản	Mô tả
1	congyiec.evn.com.vn	
2	nhaan.evn.vn	
3	evnict.evn.vn	

Switch border Internet

#	Tài sản	Mô tả
1	beta.evn.com.vn	
2	beta.tkn1.evn.com.vn	
3	dhd.evn.com.vn	
4	evntimes.vn	
5	hotroit.evn.com.vn	
6	m.evn.com.vn	
7	www.beta.evn.com.vn	

8	www.dhd.evn.com.vn	
9	www.evn.vn	
10	www.evntimes.vn	

IP2 kết nối F5 dải 125.214.0.224

#	Tài sản	Mô tả
1	gwdofficedr.evn.com.vn	

FTTH tại VHMT

#	Tài sản	Mô tả
1	117.2.115.205	

Ký số Mobifone- DOFFICE

#	Tài sản	Mô tả
1	lichtuan.evnit.evn.com.vn	
2	vpndonvi.evn.vn	

FW-DMZ Port 1/12

#	Tài sản	Mô tả
1	vpn01.evn.com.vn	